LAPORAN BUG BOUNTY · EDISI RONDE 3 · TIGA RONDE

BAKWAN FIGHT BACK

Hasil audit tiga ronde terhadap game beta “Bakwan Fight Back” di bakwan.id/game. Ronde 1 (tanpa akun): panel admin tanpa auth, bypass gerbang, loop reCAPTCHA. Ronde 2 (akun resmi): ranked vs pemain asli, verifikasi Elo, gacha, checkout Xendit error. Ronde 3 (build play.bakwan.id): downtime WD_SCHEMA_DOES_NOT_EXIST, bot sempurna via hook debug BFB_DEBUG (10W beruntun, Elo 165), 14 probe API ditolak server baru, BUG-10 terbukti perbaikan, dan analisis ekonomi gacha: Karis ≈70 tarikan — mustahil tanpa top-up.

PENGUJI

Tim QA — Z.ai Agent · Akun audit: vameb61409 (disediakan panitia)

TANGGAL PENGUJIAN

24–25 Oktober 2026 · 12 temuan · 5 kritis

Daftar Isi

1. Ringkasan Eksekutif **3**

1.1 Matriks Temuan 4

2. Ruang Lingkup dan Metodologi **5**

2.1 Ruang Lingkup 5

2.2 Metodologi 5

3. Alur Pendaftaran Akun dan Temuan reCAPTCHA (BUG-01) **6**

3.1 Gerbang Masuk Game 6

3.2 Formulir Pendaftaran dan reCAPTCHA 6

3.3 BUG-01: Loop Kedaluwarsa Tantangan Verifikasi 7

4. Bug Akses: Bypass Gerbang Login Game (BUG-02) **8**

5. Bug Akses: Panel Admin Tanpa Autentikasi (BUG-03) **10**

5.1 Penemuan 10

5.2 Kemampuan yang Terekspos 10

5.3 Bukti Kode Sumber (White-Box) 12

6. Temuan Tambahan (BUG-04 s.d. BUG-07) **13**

6.1 BUG-04: Data Pemain Tanpa Redaksi 13

6.2 BUG-05: Simulasi Pembayaran Sekali Klik 13

6.3 BUG-06: Statistik Karakter Desimal 14

6.4 BUG-07: Inkonsistensi HP Sasaran Latihan 14

7. Audit Akun Resmi: Login, Profil, dan BUG-08 **15**

7.1 Login dengan Akun yang Disediakan 15

7.2 Profil Pemain dan Data Ladder Nyata 16

7.3 BUG-08: Pengaturan Akun Diblokir Paywall (Sedang) 16

8. Ranked vs Pemain Asli: Verifikasi Sistem Elo **17**

8.1 Dua Pertandingan Nyata Malam yang Sama 17

8.2 Hasil dan Verifikasi Matematika Elo 19

8.3 Profil Lawan: Data Ladder Aktif 20

9. Misi Harian, Latihan, dan BUG-09 **21**

9.1 Sistem Hadiah Harian Produksi 21

9.2 Latihan: Sesi dengan 11 Hit Tidak Terkredit (BUG-09, Mayor) 22

9.3 Catatan Anti-Makro yang Sehat (Bukan Bug) . . . 23

10. Store, Gacha, dan BUG-10 Top-Up Xendit **24**

10.1 Store Produksi: Gacha dan Botol XP . . . 24

10.2 Harga Top-Up Berdiskon 33% . . . 25

10.3 BUG-10: Halaman Checkout Xendit Error Permanen (Kritis) . . . 27

11. Mekanisme dan Cara Bermain **28**

11.1 Konsep Dasar . . . 28

11.2 Sistem Timing dan Kerusakan . . . 28

11.3 Mode Latihan . . . 29

11.4 Mode Ranked, Elo, dan Bot . . . 29

11.5 Karakter, Skill, dan Progres . . . 31

12. Ekonomi Game, Leaderboard, dan Validasi Input **32**

12.1 Mata Uang, Hadiah Harian, dan XP . . . 32

12.2 Gacha Karakter . . . 33

12.3 Top-Up Uang Nyata . . . 33

12.4 Leaderboard Produksi . . . 34

12.5 Uji Validasi: Kode Teman dan Nickname . . . 35

13. Rekomendasi Perbaikan **37**

14. Kronologi Pengujian dan Catatan Penutup **38**

14.1 Kronologi Ringkas . . . 38

14.2 Kebersihan Pengujian . . . 39

14.3 Penutup . . . 40

15. Ronde 3: Migrasi Server, Bot Sempurna, dan Ekonomi Gacha (25 Okt 2026) **40**

15.1 BUG-11 (Kritis): Downtime Produksi — WD_SCHEMA_DOES_NOT_EXIST . . . 41

15.2 Migrasi Infrastruktur: play.bakwan.id dan Server WebSocket Dedicated . . . 42

15.3 BUG-12 (Kritis): Hook Debug BFB_DEBUG — Bot Sempurna yang Trivial . . . 43

15.4 Model Anti-Cheat sendHits: Deterministik-Replay yang Benar (dengan Catatan) . . . 45

15.5 Pengerasan Server Terbukti: 37 Panggilan Probe API Ditolak Bersih . . . 46

15.6 Analisis Ekonomi Gacha: Karis Secara Realistis Tidak Terjangkau . . . 46

15.7 Status Ulang Temuan Ronde 2 pada Build Baru . . . 48

15.8 Log Perubahan Akun Uji pada Ronde 3 . . . 49

1. Ringkasan Eksekutif

Laporan ini menyajikan hasil pengujian kualitas (QA) dan bug hunting terhadap fitur game beta **“Bakwan Fight Back”** yang berjalan di halaman **https://www.bakwan.id/game**. Pengujian dilaksanakan dalam **tiga ronde** pada 24–25 Oktober 2026 sebagai bagian dari program bug bounty 7 hari yang diumumkan pengelola situs Bakwan Universe. Ronde pertama dilakukan tanpa akun (percobaan pendaftaran mandiri via temp mail dan eksplorasi mode demo). Ronde kedua — dilakukan setelah pengembang mengonfirmasi bahwa halaman demo bukan representasi penuh game asli — menggunakan **akun resmi yang disediakan penguji dari pihak penyelenggara** (vameb61409@hiringview.com, tanpa captcha saat login), sehingga seluruh alur game produksi dapat diuji secara langsung dan mendalam. Seluruh pengujian bersifat pasif dan non-destruktif: tanpa serangan injeksi, tanpa beban berlebih ke server, dan tanpa perubahan data apa pun milik pengguna lain.

Hasil gabungan ketiga ronde menemukan **12 temuan (BUG-01 s.d. BUG-12)**, lima di antaranya tergolong kritis. Temuan paling serius pada ronde pertama adalah **panel admin game yang dapat dibuka tanpa autentikasi apa pun** melalui mode demo — temuan ini kembali diverifikasi pada ronde kedua dan **masih hidup di build terbaru 20261024-190551**. Temuan kritis kedua adalah **bypass gerbang login game** lewat URL iframe yang juga masih berfungsi. Temuan kritis ketiga adalah **loop kedaluwarsa reCAPTCHA** yang menggagalkan seluruh 6 sesi pendaftaran akun pada ronde pertama. Temuan kritis **baru** dari ronde kedua adalah **kegagalan total halaman checkout Xendit** (“Sorry, this wasn't supposed to happen”) yang membuat seluruh paket top-up — meski sudah diiklankan berdiskon 33% — tidak mungkin dibayar, ditambah dua temuan sedang/mayor: halaman Pengaturan Akun yang diblokir paywall untuk member yang sedang login (BUG-08) dan reward latihan yang tidak pernah terkredit meski syarat 10 hit terpenuhi di layar (BUG-09).

Sebagai kelanjutan, **ronde ketiga** dilaksanakan pada 25 Oktober 2026 (siang) setelah pengembang mengumumkan bahwa BUG-08 dan BUG-10 sedang dikerjakan, BUG-09 berjalan sesuai desain, serta meminta penguji menguji logika gacha hingga memperoleh karakter Legendary “Karis”. Ronde ini menangkap dua peristiwa besar: (1) **migrasi infrastruktur total** — game pindah dari berkas statis filesusr.com ke subdomain khusus **play.bakwan.id** dengan server WebSocket dedicated, disertai pembongkaran sistem battle dan Elo, penambahan hadiah login harian, dan peningkatan hadiah harian menjadi 5/15/10 bakwan; dan (2) **sekitar satu jam downtime produksi** dengan error **WD_SCHEMA_DOES_NOT_EXIST** yang menggagalkan boot game untuk seluruh pemain (BUG-11). Ronde ketiga juga membuktikan secara empiris sebuah celah klien yang serius: hook debug **window.BFB_DEBUG** yang terekspos publik memungkinkan pembuatan **bot sempurna** (80/80 hit perfect, 10 kemenangan ranked termasuk 5 beruntun, Elo 39 → 165) yang mustahil dibedakan dari pemain manusia terbaik sekalipun (BUG-12). Analisis ekonomi juga menutup misi gacha: tanpa top-up uang riil, karakter Karis membutuhkan ≈ 70 tarikan ≈ 6.300–7.000 bakwan ≈ 233 hari pengumpulan hadiah harian maksimum — karena kemenangan ranked terbukti tidak membayar bakwan sama sekali (diverifikasi pada 10 kemenangan). Di sisi positif, seluruh uji manipulasi API server (37 panggilan dalam 9 kelompok: gacha, beli/pakai item negatif, ringkasan latihan palsu, demoPay, ACL admin) **ditolak bersih oleh server baru**, dan BUG-10 terkonfirmasi **perbaikan**: invoice Xendit kini terbuat mulus.

12	5	3	82
Temuan bug	Berlabel kritis	Ronde pengujian	Bukti tangkapan layar

1.1 Matriks Temuan

ID	Temuan	Keparahan	Status
BUG-01	Loop kedaluwarsa reCAPTCHA memblokir pendaftaran akun (6 sesi gagal, 15+ ronde per sesi)	Kritis	Terkonfirmasi (R1)
BUG-02	Gerbang login game dapat dilewati: mode “Main Demo” terbuka lewat URL iframe tanpa akun	Kritis	Masih hidup (R2)
BUG-03	Panel admin terbuka penuh tanpa autentikasi; flag isAdmin=true di-hardcode pada mode demo	Kritis	Masih hidup (R2)
BUG-04	Data pemain (Elo, saldo bakwan, kode teman) terekspos di panel admin tanpa redaksi	Sedang	Masih hidup (R2)
BUG-05	Simulasi pembayaran top-up sekali klik (“BAYAR (DEMO)”) langsung mengkreditkan saldo	Sedang	Diakui dev (rollback)
BUG-06	Statistik karakter menampilkan nilai desimal (ATK 39.1, DEF 18.5) pada UI	Rendah	Terkonfirmasi (R1)
BUG-07	Inkonsistensi HP sasaran latihan: UI menampilkan 5000, konfigurasi kode 3000	Rendah	Perlu konfirmasi dev
BUG-08	Halaman “Pengaturan Akun” diblokir paywall “You don't have permissions” untuk member yang sedang login	Sedang	Baru (R2); dev: dikerjakan
BUG-09	Reward latihan tidak terkredit: hasil 11 hit (syarat UI 10) tidak memberi XP maupun bonus misi harian	Mayor	Dev: by design (R3)
BUG-10	Checkout Xendit error permanen “Sorry, this wasn't supposed to happen” — top-up mustahil dibayar	Kritis	PERBAIKAN (R3)
BUG-11	Downtime produksi ≈1 jam: game gagal boot dengan error backend WD_SCHEMA_DOES_NOT_EXIST (dampak ke seluruh pemain)	Kritis	Baru (R3); pulih sendiri
BUG-12	Hook debug klien window.BFB_DEBUG terekspos publik: jadwal note, koordinat, dan fungsi tap() terbuka — bot sempurna trivial	Kritis	Baru (R3); masih hidup

Tabel 1: Matriks temuan bug bounty Bakwan Fight Back — R1 = ronde 1 (tanpa akun), R2 = ronde 2 (akun resmi), R3 = ronde 3 (build play.bakwan.id).

Catatan penting mengenai dampak: seluruh aksi admin pada BUG-03 diuji hanya pada **mode demo** yang basis datanya tersimpan lokal di peramban (localStorage) dan berisi 8 pemain bawaan (seed/NPC). Server produksi Wix didesain memvalidasi ulang hak admin di sisi server melalui fungsi **needAdmin()**, sehingga tidak ada bukti perubahan data produksi. Meski demikian, pola “gate admin di sisi klien” tetap berisiko

tinggi dan wajib diperbaiki, karena mengekspos permukaan antarmuka admin, membingungkan penguji/peneliti, dan berpotensi menjadi jalan masuk apabila terdapat jalur lain yang lupa divalidasi.

2. Ruang Lingkup dan Metodologi

2.1 Ruang Lingkup

Target pengujian adalah fitur game beta pada halaman https://www.bakwan.id/game beserta seluruh aset yang dimuat oleh halaman tersebut, termasuk aplikasi game “Bakwan Fight Back” yang berjalan di dalam iframe. Ronde pertama menggunakan peramban Chromium otomatis (headless) dengan resolusi 1280x577, jaringan normal tanpa proxy, dan tanpa alat penguji berbayar. Email yang digunakan untuk percobaan pendaftaran adalah alamat sementara **bakkyo1lx30lbw@maxxspace.com** yang dibuat melalui layanan mail.tm, sesuai saran penyelenggara agar tidak memakai akun pribadi. Ronde kedua memakai akun resmi **vameb61409@hiringview.com** yang disediakan penyelenggara khusus untuk audit ini; login dengan akun tersebut tidak memerlukan captcha sehingga seluruh alur produksi (matchmaking ranked nyata, store, gacha, misi harian, leaderboard, sistem teman) dapat diuji end-to-end.

2.2 Metodologi

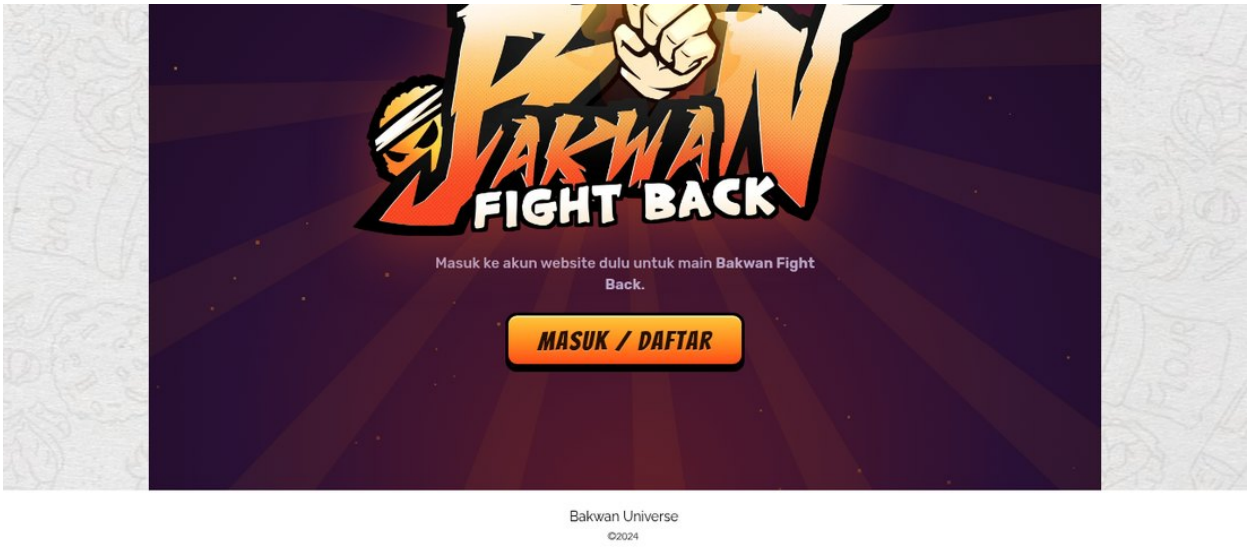
Metodologi mengikuti praktik QA biasa dengan lima tahap: (1) rekonsaisasi halaman dan pengumpulan konteks program; (2) eksplorasi alur pengguna nyata mulai dari pendaftaran, login, hingga bermain; (3) pengujian batas pada input dan alur (validasi nickname, kode teman, gacha, top-up); (4) analisis sisi klien terhadap kode sumber game yang termuat (white-box) untuk memahami mekanisme dan mencari konfigurasi yang keliru; serta (5) dokumentasi setiap temuan dengan tangkapan layar dan replikasi langkah demi langkah. Pada ronde kedua, tambahan verifikasi kuantitatif dilakukan: matematika Elo dihitung ulang dari hasil match nyata, konsistensi saldo bakwan dilacak antar transaksi, dan reward misi harian diverifikasi sebelum-sesudah reload halaman.

Batasan etika yang diterapkan: tidak ada serangan injeksi SQL/XSS aktif ke backend, tidak ada brute force, tidak ada spamming permintaan (DoS), tidak ada upaya mengubah data server, dan tidak ada penggunaan akun milik orang lain tanpa izin. Semua aksi admin pada mode demo hanya dilihat, tidak pernah disimpan. Akun temp mail tidak jadi dibuat karena pendaftaran gagal total pada tahap verifikasi reCAPTCHA (BUG-01), sehingga tidak ada akun uji yang perlu dihapus; inbox diverifikasi kosong pada akhir sesi. Akun resmi ronde kedua adalah milik penyelenggara dan **sengaja tidak dihapus** — seluruh perubahan pada akun tersebut (dua kekalahan ranked, satu gacha, penurunan saldo 105 menjadi 20 bakwan) merupakan konsekuensi normal dari gameplay uji dan dilaporkan transparan pada Bab 14. Tidak ada invoice Xendit yang dibayar dan tidak ada pesan yang dikirim ke pemain lain.

3. Alur Pendaftaran Akun dan Temuan reCAPTCHA (BUG-01)

3.1 Gerbang Masuk Game

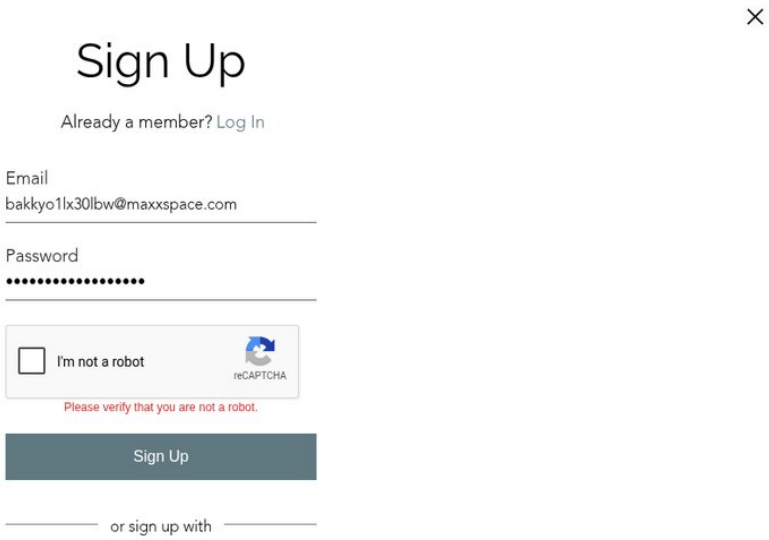
Halaman game menyambut pengunjung dengan judul “PON BAKWAN — FIGHT BACK” dan pesan eksplisit: “Masuk ke akun website dulu untuk main Bakwan Fight Back”, diikuti tombol besar MASUK / DAFTAR. Pada faktur tersemat (iframe) juga terdapat tombol “Masuk / Daftar” yang membuka dialog login khas Wix dengan tiga pilihan: Google, Facebook, dan Email. Jalur email dipilih karena tidak memerlukan akun pihak ketiga.



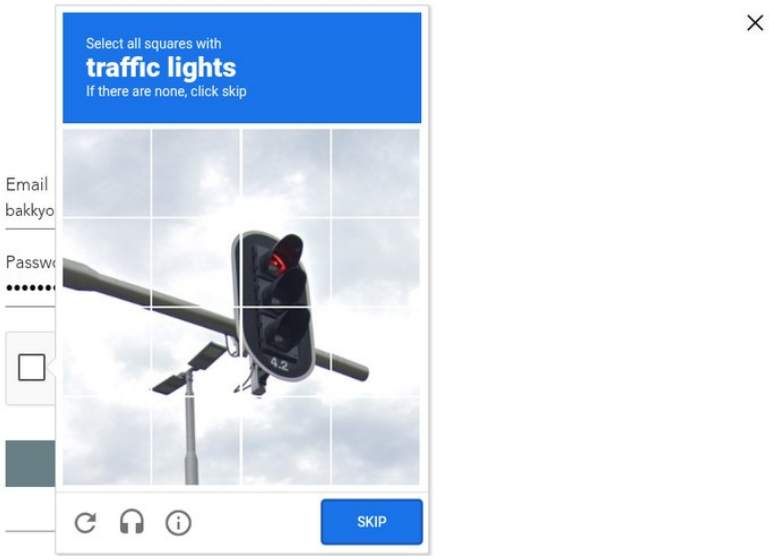
Gambar 1: Gerbang game di bakwan.id/game mengharuskan pengguna masuk akun sebelum bermain.

3.2 Formulir Pendaftaran dan reCAPTCHA

Formulir pendaftaran email hanya meminta dua isian: alamat email dan kata sandi. Setelah diisi dan tombol Sign Up ditekan, muncul persyaratan centang reCAPTCHA v2 (“I'm not a robot”). Pencetangan kotak centang memicu tantangan gambar bertumpuk (multi-round): pilih semua petak berisi sepeda motor, lampu lalu lintas, bus, sepeda, tangga, zebra cross, hidran kebakaran, hingga grid 3x3 bergaya “select all images with X” yang gambarnya terus berganti.



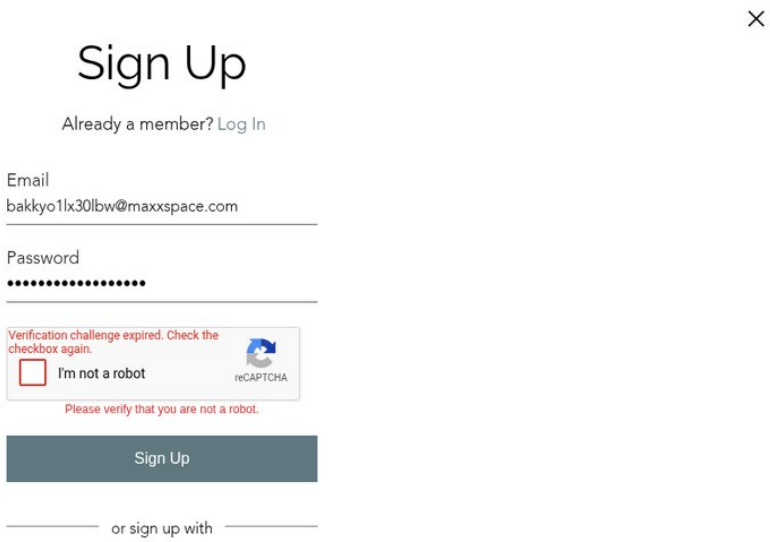
Gambar 2: Formulir pendaftaran meminta verifikasi reCAPTCHA sebelum Sign Up dapat dilanjutkan.



Gambar 3: Contoh tantangan gambar bertingkat; jawaban benar mengganti gambar baru tanpa jeda.

3.3 BUG-01: Loop Kedaluwarsa Tantangan Verifikasi

Deskripsi. Sesi tantangan reCAPTCHA berulang kali berakhir dengan pesan “Verification challenge expired. Check the checkbox again.” ketika pengguna masih berada di tengah proses menjawab ronde-ronde gambar. Seluruh progres ronde hilang dan pengguna dipakai mengulang dari kotak centang. Dalam pengujian ini tercatat **6 sesi gagal berturut-turut**; sesi terpanjang menuntut **15+ ronde** gambar sebelum akhirnya kedaluwarsa tepat sebelum verifikasi final diterima.



Gambar 4: Pesan "Verification challenge expired" muncul setelah pengguna menyelesaikan banyak ronde tantangan.

Langkah replikasi. (1) Buka bakwan.id/game, tekan MASUK / DAFTAR, pilih Sign up with email; (2) isi email dan kata sandi; (3) centang reCAPTCHA; (4) jawab tantangan gambar bertahap sampai muncul beberapa ronde penggantian gambar; (5) amati pesan expired sebelum verifikasi selesai. Tingkat reproduksi: 6/6 sesi pada pengujian ini, termasuk sesi yang dijawab sangat cepat (rata-rata di bawah 3 detik per ronde).

Dampak. Pendaftaran via email praktis terblokir bagi pengguna biasa: setiap sesi menuntut banyak ronde (indikasi skor risiko Google yang tinggi terhadap sesi), sementara umur sesi tantangan pendek, sehingga loop kegagalan hampir pasti terjadi. Pengguna baru kehilangan akses ke fitur utama (game ranked/leaderboard), dan potensi pertumbuhan pemain terhambat. Rekomendasi perbaikan ada pada Bab 9.

4. Bug Akses: Bypass Gerbang Login Game (BUG-02)

Deskripsi. Halaman bakwan.id/game menuntut login sebelum bermain, namun aplikasi game sesungguhnya adalah satu berkas HTML yang dimuat dari subdomain berkas statis Wix: **https://www-bakwan-id.filesusr.com/html/c1ed9b_8756bf37c38fda71b8c9af151086146e.html**.
Membuka URL tersebut langsung di peramban (tanpa cookie, tanpa sesi, tanpa akun) memunculkan layar judul game lengkap dengan tombol **MAIN DEMO** dan keterangan "Versi demo - progres disimpan di browser ini". Satu klik kemudian langsung masuk ke menu utama game.

Dengan kata lain, syarat "masuk akun dulu untuk main" hanya ditegakkan pada lapisan halaman induk (klien), bukan pada aplikasi game itu sendiri. Peneliti hanya perlu melihat atribut src iframe pada DOM halaman untuk mengekstrak URL ini — langkah yang dapat dilakukan siapa pun lewat DevTools tanpa alat khusus.



Gambar 5: URL iframe game dibuka langsung: layar judul dengan tombol MAIN DEMO muncul tanpa login.

Dampak. (1) Persyaratan akun untuk fitur beta tidak efektif, sehingga telemetri pemain beta dan pembatasan usia/aturan komunitas dapat terlewati; (2) mode demo menyimpan progres lokal tanpa kaitan akun sehingga leaderboard beta dapat tercemar data uji; (3) kombinasi dengan BUG-03 membuat seluruh panel admin terekspos bagi pengunjung anonim. Mode demo sebagai fitur resmi tidak masalah; masalahnya adalah ketidakselarasan antara kebijakan gerbang dan perilaku aplikasi, serta tidak adanya penanda bahwa demo adalah jalur alternatif yang disengaja.

Status ronde kedua (25 Okt). Temuan ini **masih hidup pada build terbaru** 20261024-190551: URL yang sama tetap terbuka publik dan menampilkan layar “Versi demo — progres disimpan di browser ini” dengan tombol MAIN DEMO, tanpa cookie maupun sesi. Ekspor berkas game pun tetap identik (md5 tidak berubah), sehingga seluruh analisis white-box pada laporan ini tetap berlaku untuk versi yang sedang tayang.



Gambar 6: Verifikasi ulang ronde kedua: URL filesusr.com tetap membuka mode demo tanpa login pada build terbaru.

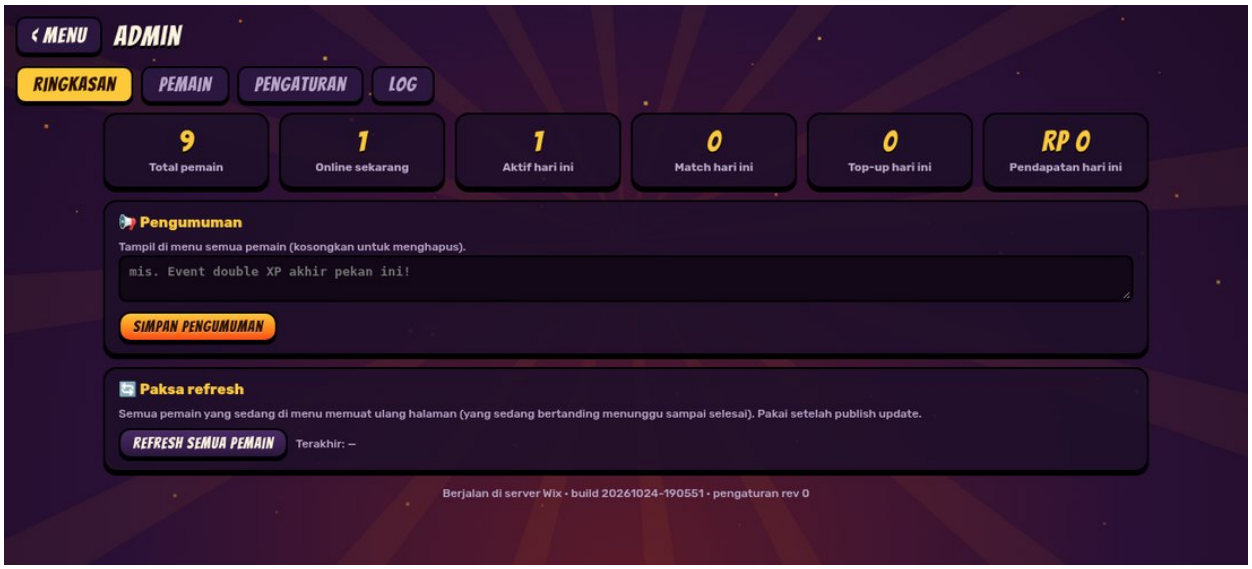
5. Bug Akses: Panel Admin Tanpa Autentikasi (BUG-03)

5.1 Penemuan

Setelah masuk ke menu utama mode demo (lihat Bab 4), bilah atas game menampilkan tombol berwarna merah berlabel **Admin** di samping tombol Riwayat dan Layar penuh. Menekannya membuka panel administrasi empat tab: **Ringkasan**, **Pemain**, **Pengaturan**, dan **Log** — semuanya dapat diakses tanpa kata sandi, tanpa konfirmasi, dan tanpa sesi akun apa pun. Footer panel membaca “Berjalan di server Wix · build 20261024-190551· pengaturan rev 0”.



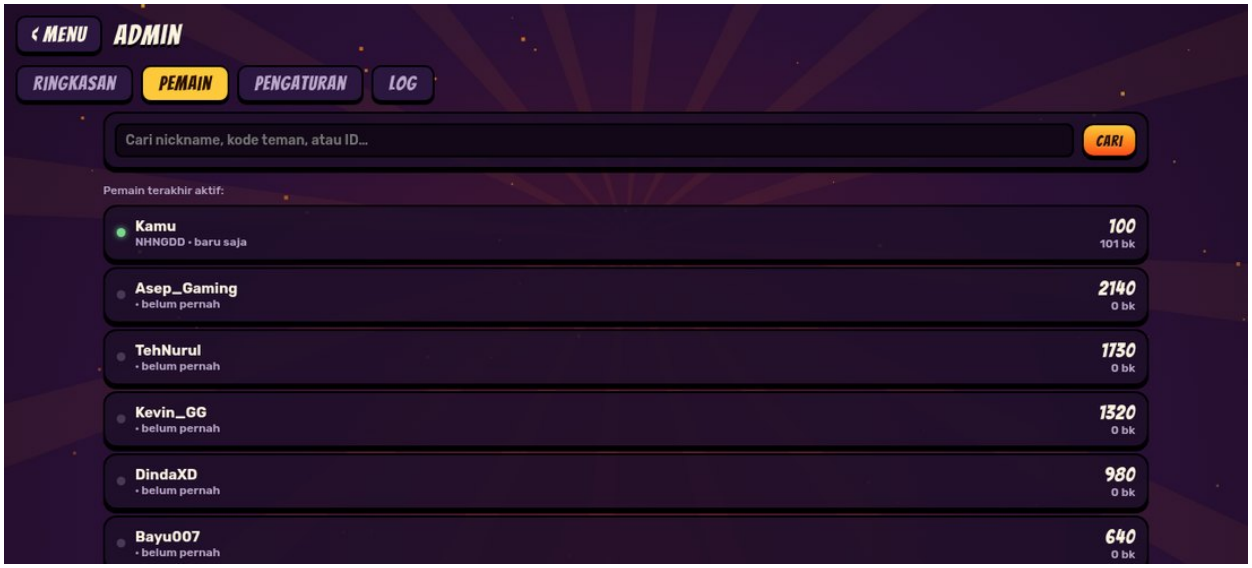
Gambar 7: Menu utama mode demo; tombol Admin tampak di kanan atas tanpa syarat apa pun.



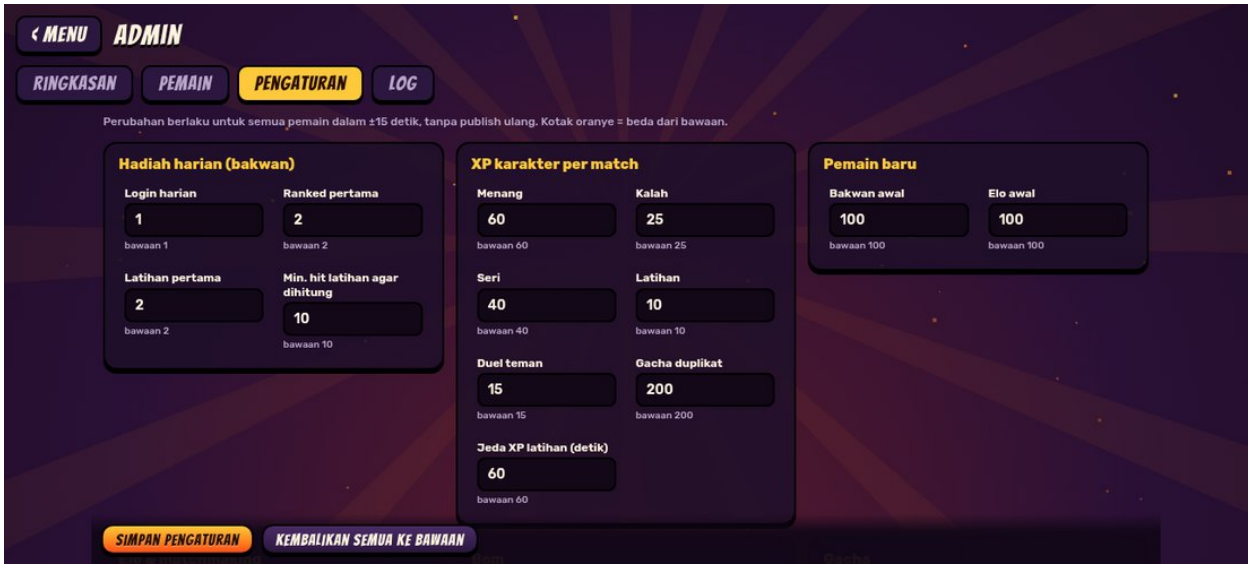
Gambar 8: Tab Ringkasan panel admin: statistik pemain, form Pengumuman siap kirim ke semua pemain, dan tombol “Refresh semua pemain”.

5.2 Kemampuan yang Terekspos

Panel admin ini bukan sekadar tampilan mati. Tab Ringkasan menyediakan formulir **Pengumuman** yang menurut keterangannya "tampil di menu semua pemain" lengkap dengan tombol SIMPAN PENGUMUMAN, serta tombol **REFRESH SEMUA PEMAIN** yang memaksa seluruh klien yang sedang aktif memuat ulang halaman. Tab Pengaturan memaparkan seluruh parameter ekonomi game yang dapat disunting dan disimpan: hadiah harian, XP per hasil pertandingan, Elo awal, saldo awal pemain baru, hingga gacha. Tab Pemain menyediakan pencarian nickname/kode teman/ID beserta daftar pemain dengan rating Elo dan saldo.

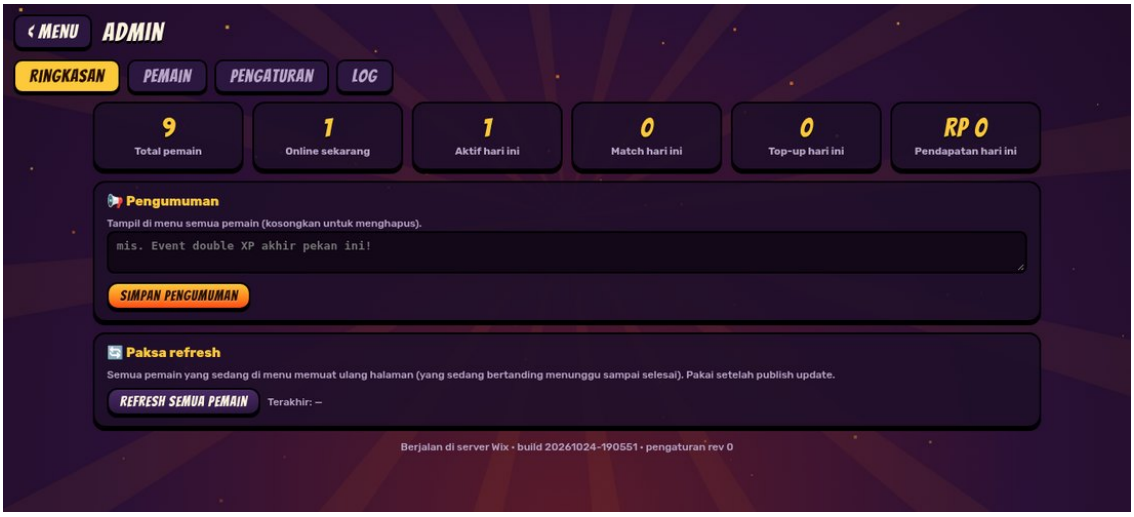


Gambar 9: Tab Pemain: nickname, Elo, dan saldo bakwan pemain tampil tanpa redaksi.

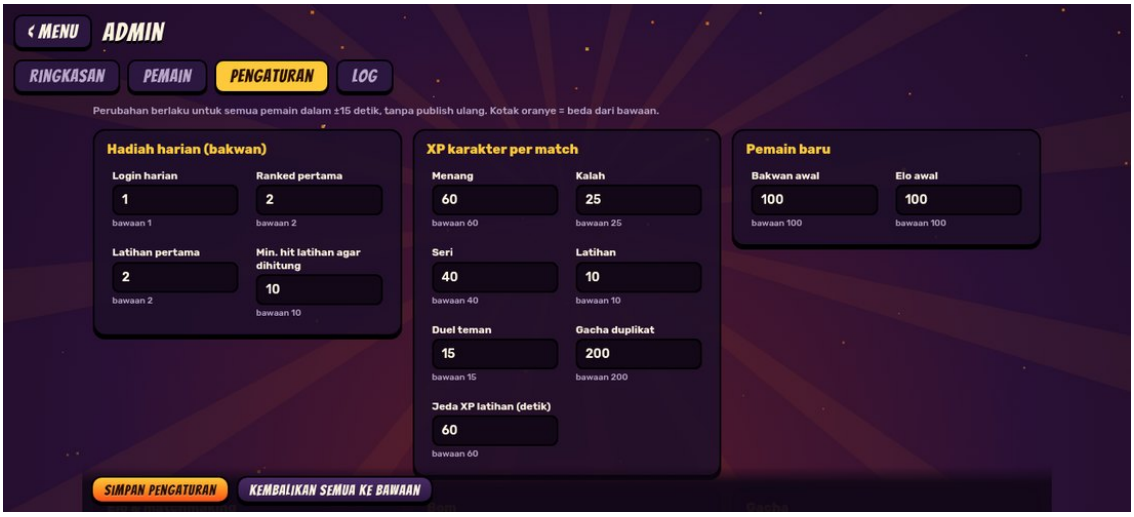


Gambar 10: Tab Pengaturan: seluruh parameter ekonomi game dapat disunting dan disimpan tanpa autentikasi.

Status ronde kedua (25 Okt). Panel admin demo **masih dapat dibuka tanpa autentikasi** pada build terbaru — termasuk editor Pengumuman, tombol REFRESH SEMUA PEMAIN, daftar pemain, LOG, dan seluruh parameter ekonomi di tab Pengaturan (hadiah harian, XP per match, Elo/saldo awal, ambang hit latihan). Nilai-nilai pada tab tersebut pula yang menjadi kunci analisis BUG-09: panel menampilkan "Min. hit latihan agar dihitung: 10" sementara server produksi berperilaku berbeda. Dalam pengujian ulang ini tidak ada satu pun tombol simpan yang ditekan.



Gambar 11: Verifikasi ulang ronde kedua: panel admin demo tetap terbuka penuh — Ringkasan, Pengumuman, dan Paksa refresh tanpa auth.



Gambar 12: Verifikasi ulang: tab Pengaturan memaparkan seluruh angka balance (termasuk "Min. hit latihan: 10" yang menjadi konteks BUG-09).

5.3 Bukti Kode Sumber (White-Box)

Analisis berkas HTML game mengonfirmasi akar masalahnya: pada inisialisasi mode demo, objek konteks pengguna dibuat dengan flag admin bernilai true secara permanen:

```
var ctx = { memberId: 'demo-you', name: 'Kamu',
  email: 'demo@admin', isAdmin: true };
```

Flag inilah yang membuat tombol admin tampil (pemilihan tombol dikontrol oleh $$('.adminbtn').forEach(b => b.hidden = !G.isAdmin)). Pada mode produksi, nilai isAdmin diambil dari respons server (r.isAdmin) dan seluruh fungsi admin dijaga fungsi **needAdmin(ctx)** yang melempar kesalahan NOT_ADMIN bila konteks bukan admin — artinya validasi sisi server untuk data produksi tampaknya ada. Meski demikian, ditemukan pula bahwa basis data demo di-seed dengan 8 akun tiruan:

```
var fake = [['Asep_Gaming', 2140, 'presiden'], ['TehNurul', 1730, 'haze'],
  ['Kevin_GG', 1320, 'kazera'], ['DindaXD', 980, 'veradinita'],
  ['Bayu007', 640, 'dai'], ['Rara.exe', 410, 'shinon'],
  ['UcupPro', 230, 'mefelz'], ['MasJajang', 150, 'botak']];
```

Data tiruan inilah yang tampil di panel admin, leaderboard, dan matchmaking demo. Ini penting untuk penilaian dampak: data yang terekspos pada BUG-04 adalah data uji, bukan data pemain produksi. Namun karena tampilannya identik dengan pemain nyata (lengkap dengan tag “MURID TELADAN”, “PEMAIN BFB”, jumlah menang/kalah), penguji maupun pemain baru tidak dapat membedakannya — hal ini sendiri merupakan masalah UX dan integritas data beta.

Dampak ringkas. Pada mode demo: siapa pun dapat (a) menyiarkan pengumuman apa pun termasuk tautan phishing ke “semua pemain” lokal, (b) memaksa refresh massal, (c) mengubah seluruh parameter ekonomi, (d) melihat data pemain tanpa redaksi. Pada produksi: belum ada bukti eksploitasi karena validasi server hadir; namun permukaan UI admin yang terbuka untuk anonim tetap harus ditutup, dan prinsip “deny by default” perlu diterapkan pada mode demo.

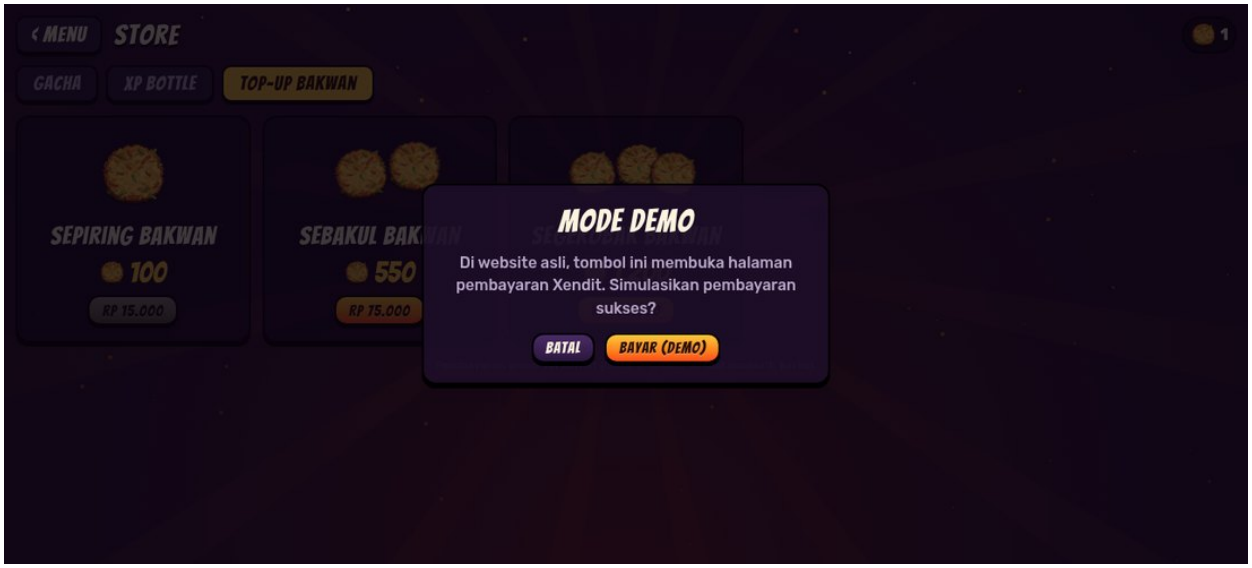
6. Temuan Tambahan (BUG-04 s.d. BUG-07)

6.1 BUG-04: Data Pemain Tanpa Redaksi

Panel admin dan leaderboard menampilkan data pemain secara penuh: nickname, Elo, saldo bakwan, kode teman, serta statistik menang/kalah. Tidak ada mekanisme redaksi atau masking (misalnya Asep****). Pada mode demo data ini berupa seed lokal, tetapi pola tampilan yang sama diharapkan berlaku bagi admin produksi; tanpa pembatasan peran bertingkat, setiap pemegang akses admin melihat data mentah seluruh komunitas. Sebagai catatan risiko lanjutan: kode teman bersifat pengenal yang dapat dipakai mengirim permintaan duel, sehingga penampakannya di panel yang sama sebaiknya dibatasi konteksnya.

6.2 BUG-05: Simulasi Pembayaran Sekali Klik

Store menyediakan tiga paket top-up (100 bakwan = Rp 15.000; 550 = Rp 75.000; 1.200 = Rp 150.000) yang dalam mode demo tidak membuka halaman Xendit, melainkan menampilkan dialog “MODE DEMO - Simulasikan pembayaran sukses?” dengan tombol **BAYAR (DEMO)**. Satu klik langsung menambahkan 100 bakwan ke saldo (terverifikasi 1 menjadi 101). Pada kode, jalur ini dipetakan ke fungsi creditPurchase tanpa validasi pembayaran nyata. Meskipun berlaku lokal, dialog ini berbahaya jika suatu saat digabung dengan backend uji: cukup satu paramater mode yang keliru untuk mengkreditkan saldo tanpa uang. Disarankan mode demo menggunakan mata uang terpisah (mis. demo-bakwan) dan banner tegas.

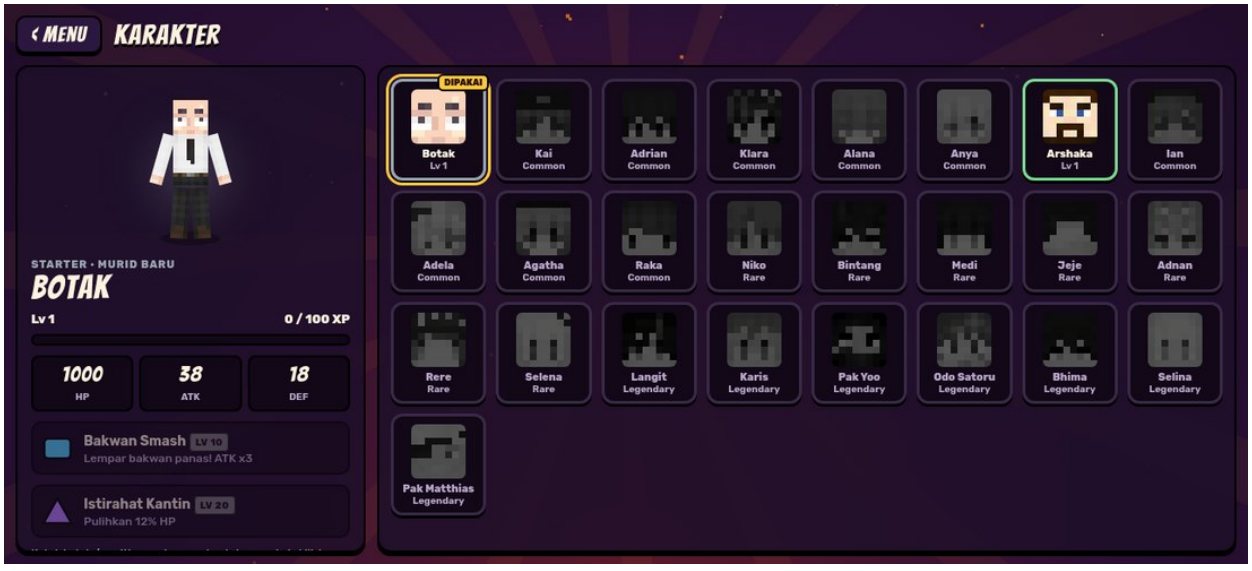


Gambar 13: Dialog simulasi pembayaran demo; satu klik langsung mengkreditkan saldo.

Tindak lanjut pengembang. Pada ronde kedua, pita pengumuman resmi di halaman game mengonfirmasi temuan ini secara publik: top-up “palsu” pada rentang 18:00–20:45 telah di-rollback “karena tadi sistem top up masih pakai test system”. Alur produksi sekarang sudah memanggil createTopup dan membuka invoice Xendit sungguhan (bukan simulasi), meski checkout-nya kini gagal permanen — lihat BUG-10 pada Bab 10.

6.3 BUG-06: Statistik Karakter Desimal

Setelah Botak dinaikkan ke Level 2 dengan Botol XP, panel karakter menampilkan ATK 39.1 dan DEF 18.5. Nilai pecahan seperti ini pada RPG kasual mengurangi keterbacaan dan terkesan belum selesai; disarankan pembulatan ke bilangan bulat pada lapisan presentasi, atau satu angka desimal dengan aturan konsisten.



Gambar 14: Panel karakter: ATK 39.1 dan DEF 18.5 tampil desimal setelah naik level.

6.4 BUG-07: Inkonsistensi HP Sasaran Latihan

Layar latihan menampilkan “Sasaran · 5000/5000”, sementara konfigurasi pada berkas game yang diuji mendefinisikan HP karung latihan 3000. Selisih ini bisa berasal dari versi build yang berbeda antara berkas

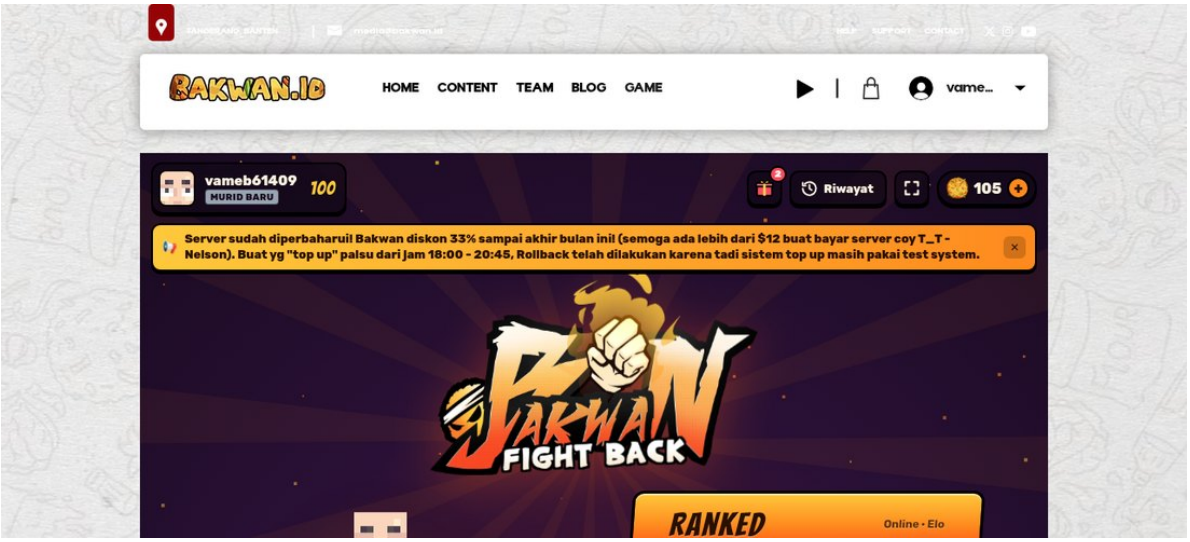
statis dan konfigurasi server, atau penskalaan level yang tidak terdokumentasi. Dampaknya kecil, tetapi membingungkan penguji dan pemain yang membaca kode; disarankan disinkronkan atau didokumentasikan.

7. Audit Akun Resmi: Login, Profil, dan BUG-08

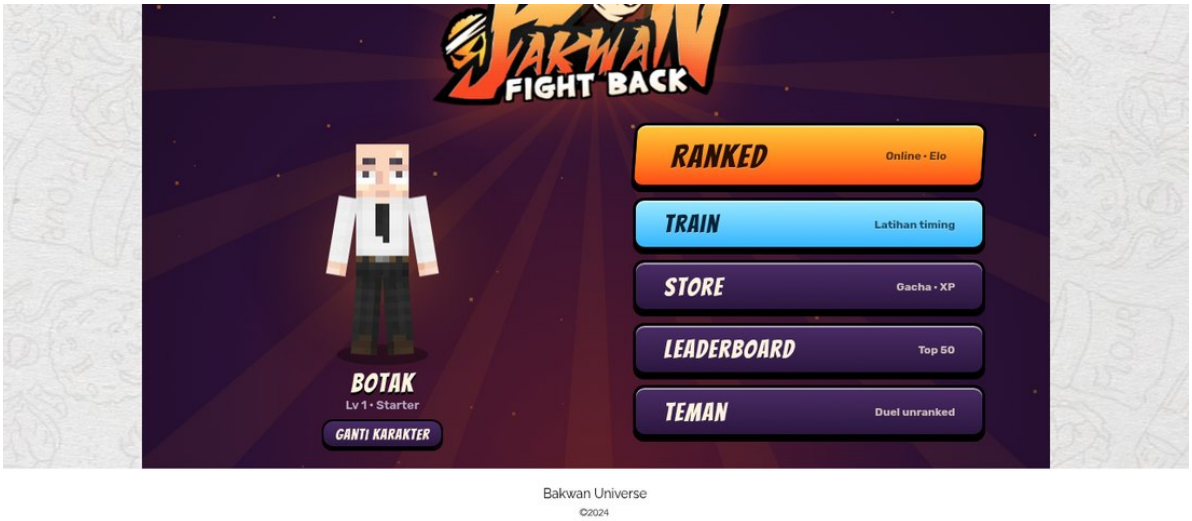
7.1 Login dengan Akun yang Disediakan

Ronde kedua dimulai dengan login menggunakan akun resmi vameb61409@hiringview.com melalui tombol “Log In” → “Log in with Email” pada situs. Tidak ada captcha yang diminta — berkebalikan total dengan alur pendaftaran pada ronde pertama yang selalu berakhir gagal (BUG-01). Permintaan login tertangkap pada jaringan sebagai panggilan ke **_api/iam/authentication/v2/login** milik Wix, disusul pembuatan sesi melalui **createSessionCookie** dan penerbitan **access-tokens**; seluruhnya sukses dalam satu percobaan. Setelah login, halaman game memuat aplikasi dengan status akun lengkap: nama vameb61409, badge rank “Murid Baru”, Elo 100, saldo 105 bakwan, ikon hadiah dengan badge 2 misi tersisa, serta pita pengumuman dari pengembang.

Pita pengumuman tersebut bernilai bukti penting: **“Server sudah diperbaharui! Bakwan diskon 33% sampai akhir bulan ini … Buat yg 'top up' palsu dari jam 18:00 - 20:45, Rollback telah dilakukan karena tadi sistem top up masih pakai test system.”** Pengembang mengakui secara publik bahwa sistem top-up sempat berjalan dalam mode uji dan pemain yang melakukan pembayaran pada rentang tersebut telah di-rollback. Temuan ini menegaskan laporan ronde pertama (BUG-05) dan menjadi konteks langsung bagi BUG-10 pada Bab 10: integrasi pembayaran memang sedang bermasalah, dan kini kondisi terbarunya dapat diuji langsung.



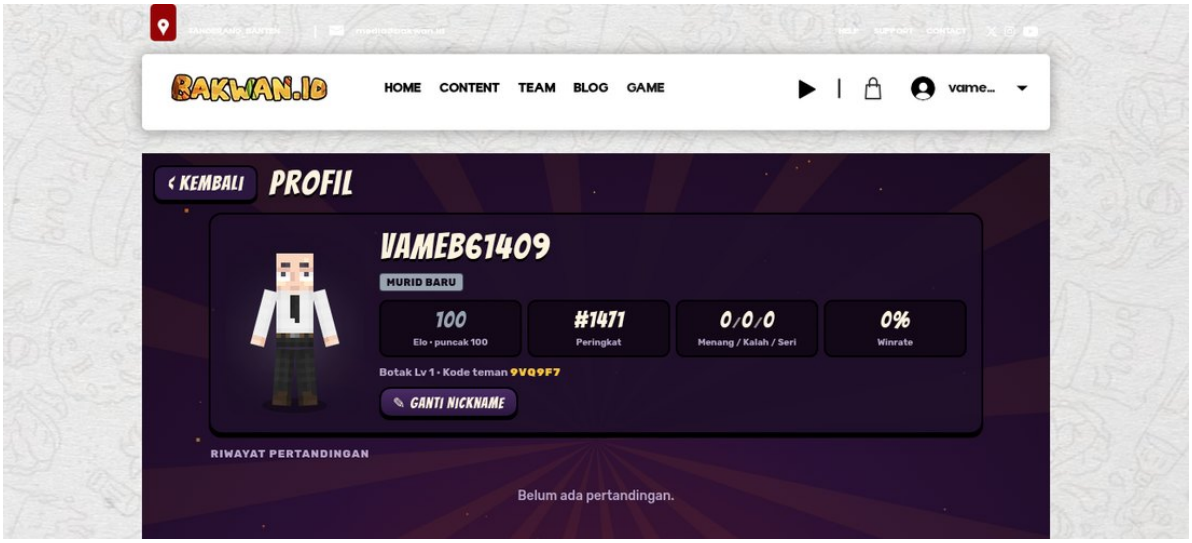
Gambar 15: Berhasil login dengan akun resmi: vameb61409 (Murid Baru), Elo 100, saldo 105 bakwan, badge 2 misi harian, dan pita pengumuman rollback top-up dari pengembang.



Gambar 16: Menu utama game produksi dengan akun resmi: karakter Botak Lv 1 · Starter, tombol Ranked, Train, Store, Leaderboard, dan Teman.

7.2 Profil Pemain dan Data Ladder Nyata

Tombol “Riwayat” membuka halaman Profil yang kini menampilkan data ladder produksi: Elo beserta puncaknya, nomor peringkat global, rekor menang/kalah/seri, winrate, karakter aktif beserta levelnya, **kode teman pribadi 9VQ9F7**, dan riwayat 20 pertandingan terakhir. Sebelum pertandingan pertama, akun menampilkan Elo 100 (puncak 100), peringkat **#1471**, rekor 0/0/0, dan winrate 0% dengan status “Belum ada pertandingan”. Nomor peringkat ini mengonfirmasi bahwa basis data pemain produksi berisi ribuan akun — indikasi adopsi beta yang luas.



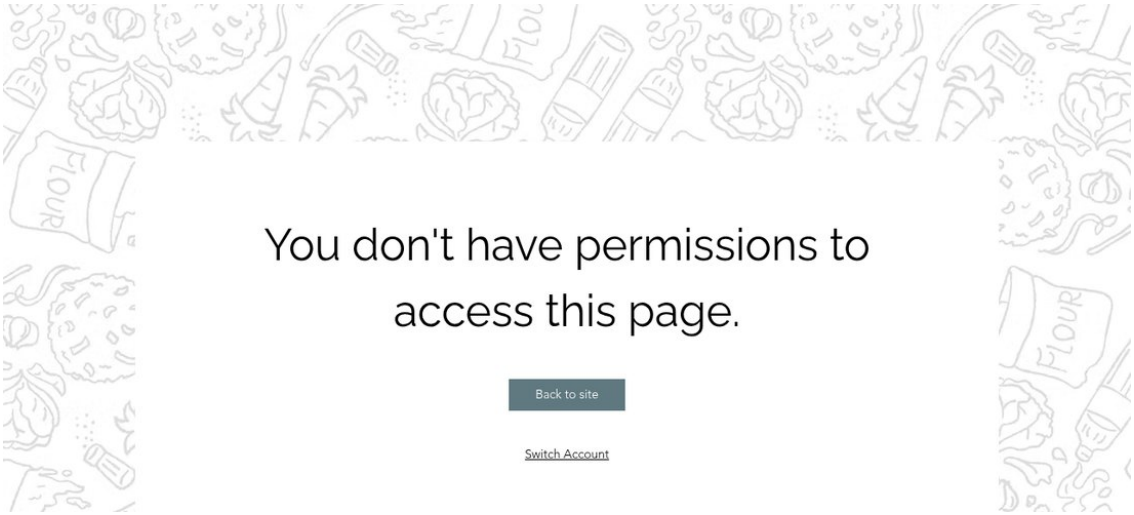
Gambar 17: Profil akun sebelum bertanding: Elo 100 (puncak 100), peringkat #1471, 0/0/0, winrate 0%, kode teman 9VQ9F7, riwayat kosong.

7.3 BUG-08: Pengaturan Akun Diblokir Paywall (Sedang)

Dari menu akun Wix di pojok kanan atas, opsi **“Pengaturan Akun”** tidak membuka halaman pengaturan, melainkan dialihkan ke paywall Wix dengan pesan **“You don't have permissions to access this page.”** beserta tombol “Back to site” dan “Switch Account”. URL yang dihasilkan adalah **/paywall?appSectionPar**

ams={\"restrictedPageId\":\"v6bn6\",\"restrictedPagePath\":\"/account-settings\"} — pola khas halaman Wix Members yang salah konfigurasi perizinannya (halaman account-settings diset terbatas untuk peran tertentu, padahal seharusnya terbuka untuk semua member yang sudah login).

Dampak praktisnya: member biasa **tidak dapat mengakses pengaturan akunnya sendiri** — misalnya mengubah data profil, mengelola notifikasi, atau mencari opsi penghapusan akun. Untuk program beta yang menjanjikan “akun dapat dihapus”, hilangnya akses ke halaman pengaturan berarti jalur penghapusan mandiri ikut tertutup dan pemain harus menghubungi pengembang secara manual. Temuan ini mudah diperbaiki dari editor Wix (Members Area → Settings → ubah izin halaman /account-settings menjadi “All members”) tanpa perubahan kode apa pun.

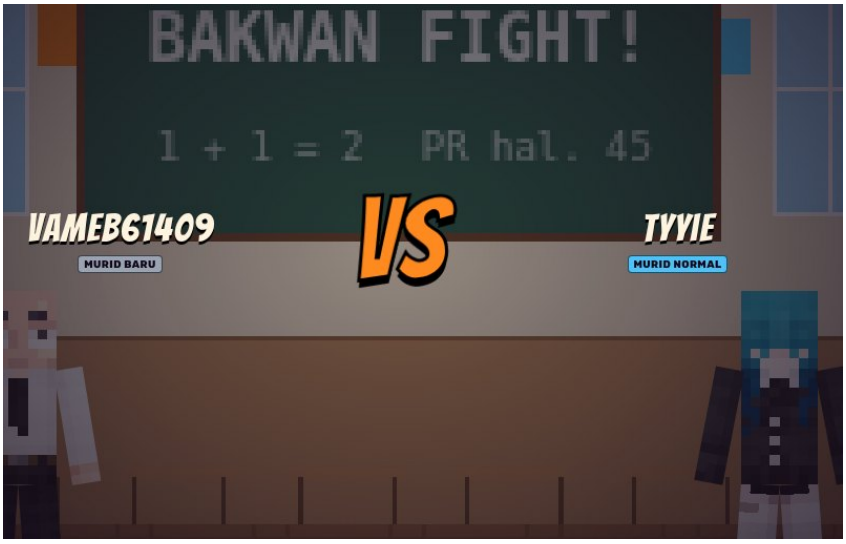


Gambar 18: BUG-08: klik “Pengaturan Akun” mengarah ke paywall “You don't have permissions to access this page.” untuk member yang sedang login.

8. Ranked vs Pemain Asli: Verifikasi Sistem Elo

8.1 Dua Pertandingan Nyata Malam yang Sama

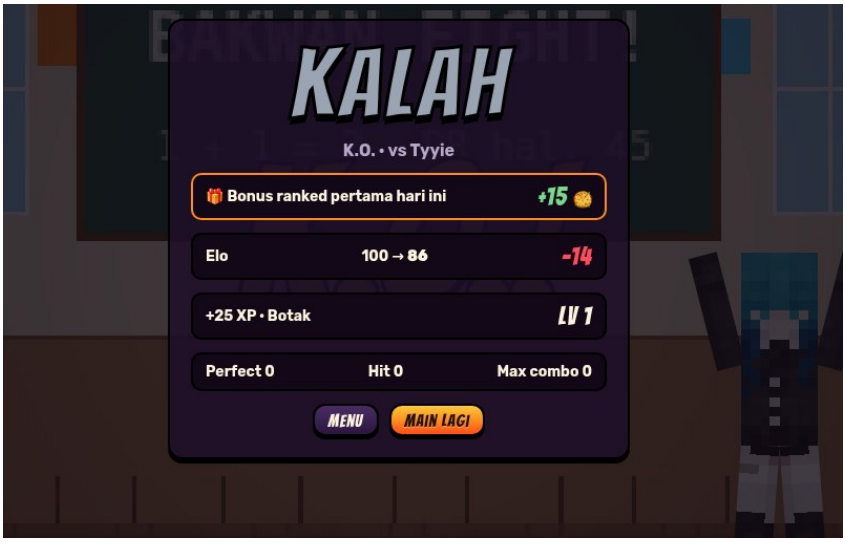
Menekan tombol **RANKED** langsung memasangkan akun uji dengan pemain asli (bukan bot) dalam hitungan detik. Pertandingan pertama adalah melawan **Tyyie** (badge “Murid Normal”, karakter Alana), berlangsung di peta kelas dengan papan tulis “BAKWAN FIGHT! 1+1=2 PR hal. 45”. Pertandingan kedua melawan **Lia__multifandom** di peta halaman sekolah. Kedua lawan terbukti manusia: nama mereka tidak ada dalam daftar 20 nama bot internal, profil mereka dapat dibuka, dan riwayat pertandingan mereka mencatat duel-duel lain pada menit yang sama (04.37–04.40 WIB) — termasuk Tyyie menang +12, +18, +15 melawan tiga pemain berbeda hanya dalam rentang dua menit.



Gambar 19: Matchmaking nyata: VAMEB61409 (Murid Baru) vs Tyyie (Murid Normal) di peta kelas.



Gambar 20: Awal pertarungan: lingkaran bernomor menyusut, banner skill lawan "LAWAN: LEMPAR PENGHAPUS", dan indikator MISS pada sisi pemain.

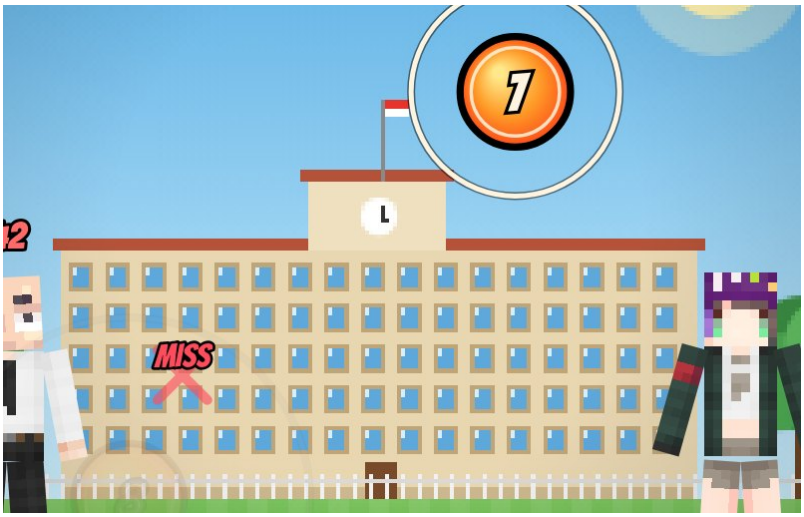


Gambar 21: Pertarungan berlangsung: skill shape dan indikator damage tampil bersamaan dengan catatan baru yang muncul.

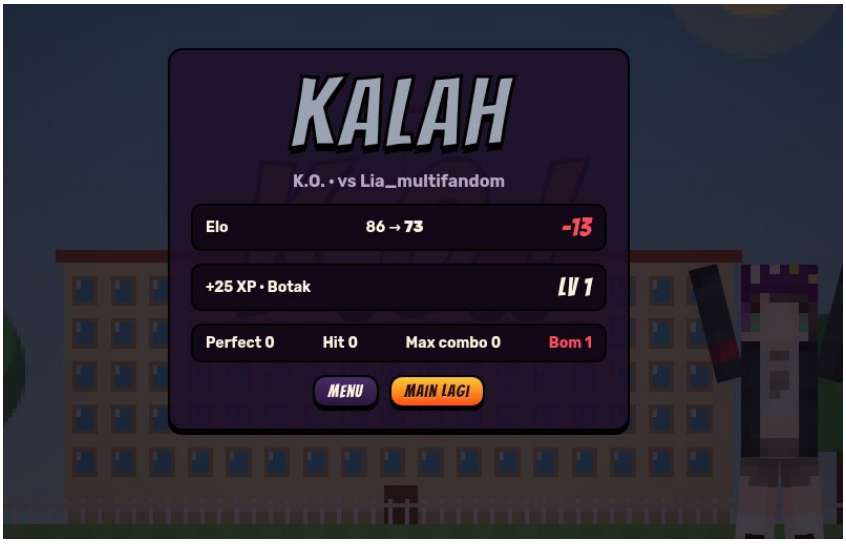
8.2 Hasil dan Verifikasi Matematika Elo

Kedua pertandingan berakhir KALAH K.O. untuk akun uji (masih Murid Baru, karakter starter Lv 1 tanpa skill aktif). Hasil pertama: **Elo 100 → 86 (−14)**, +25 XP Botak, plus bonus “ranked pertama hari ini” **+15 bakwan**. Hasil kedua: **Elo 86 → 73 (−13)**, +25 XP, dan statistik **“Bom 1”** — bukti langsung bahwa lingkaran bom palsu ikut terekam ketika penguji menyentuhnya. Dengan formula standar ΔElo = K·(score − E) dan K=40 untuk lawan nyata, −14 mengimplikasikan Elo Tyyie ≈ 208 dan −13 mengimplikasikan Elo Lia ≈ 213 pada momen match — konsisten dengan badge “Murid Normal” (rentang Elo 201–500) dan dengan profil Tyyie yang terbaca 236 Elo setelah rangkaian kemenangannya. Sistem Elo produksi dengan demikian **terverifikasi bekerja sesuai desain**.

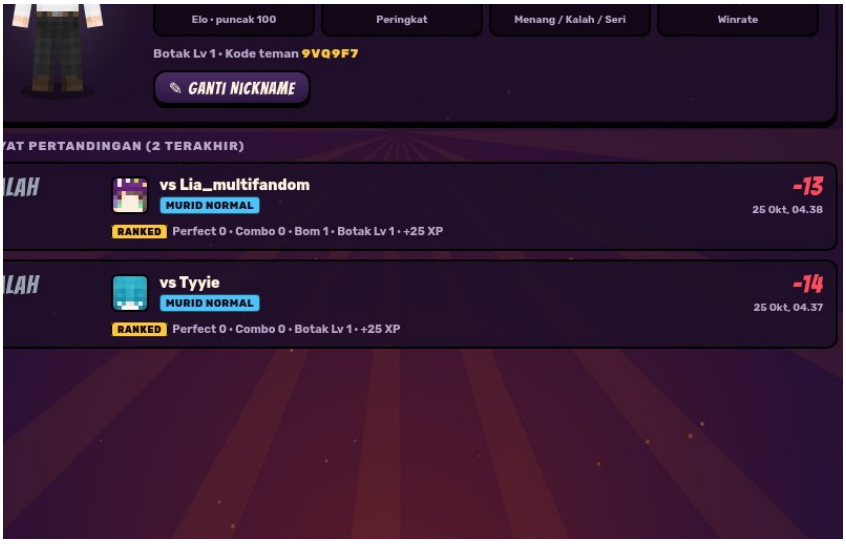
Perubahan peringkat juga tercatat: dari #1471 (belum bertanding) menjadi **#4187** setelah dua kekalahan — menandakan lebih dari 4.000 pemain memiliki Elo di atas 73. Riwayat pertandingan mencatat detail lengkap per baris: hasil, mode RANKED, lawan beserta badge-nya, statistik Perfect/Combo/Bom, karakter dan level, XP yang diterima, delta Elo berwarna, serta waktu WIB dua baris desimal. Baris riwayat dapat diklik untuk membuka profil lawan — fitur yang bekerja baik dan menghasilkan data lintas-akun yang kaya.



Gambar 22: Pertandingan kedua vs Lia__multifandom: indikator MISS di sisi pemain, catatan bernomor muncul di kanvas halaman sekolah.



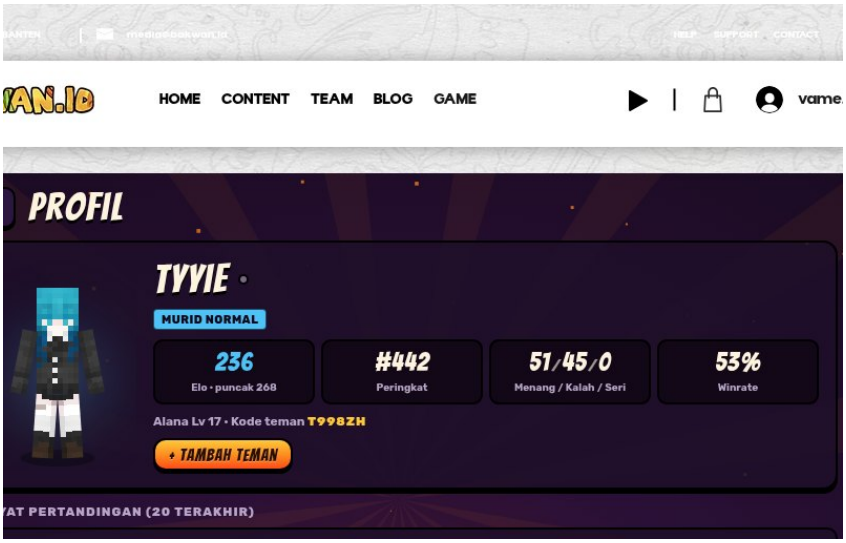
Gambar 23: Hasil match kedua: KALAH K.O., Elo 86 → 73 (−13), +25 XP, dan "Bom 1" tercatat — bukti mekanik bom palsu aktif di ranked produksi.



Gambar 24: Riwayat pertandingan produksi: dua kekalahan ranked dengan delta Elo −13/−14, timestamp WIB, dan detail Perfect/Combo/Bom per baris.

8.3 Profil Lawan: Data Ladder Aktif

Membuka profil Tyyie dari baris riwayat menampilkan potret ladder yang sehat: Elo 236 (puncak 268), peringkat **#442**, rekor **51 menang / 45 kalah / 0 seri**, winrate 53%, karakter Alana yang **naik dari Lv 16 ke Lv 17** di antara dua pertandingan, kode teman T9Q8ZH, tombol "+ Tambah Teman", dan indikator online/offline. XP +60 per kemenangan dan +25 per kekalahan pada riwayat lawan sama persis dengan konfigurasi internal (xpWin=60, xpLose=25) — konsistensi lintas-akun ini menandakan server produksi dan klien memakai aturan yang sama.

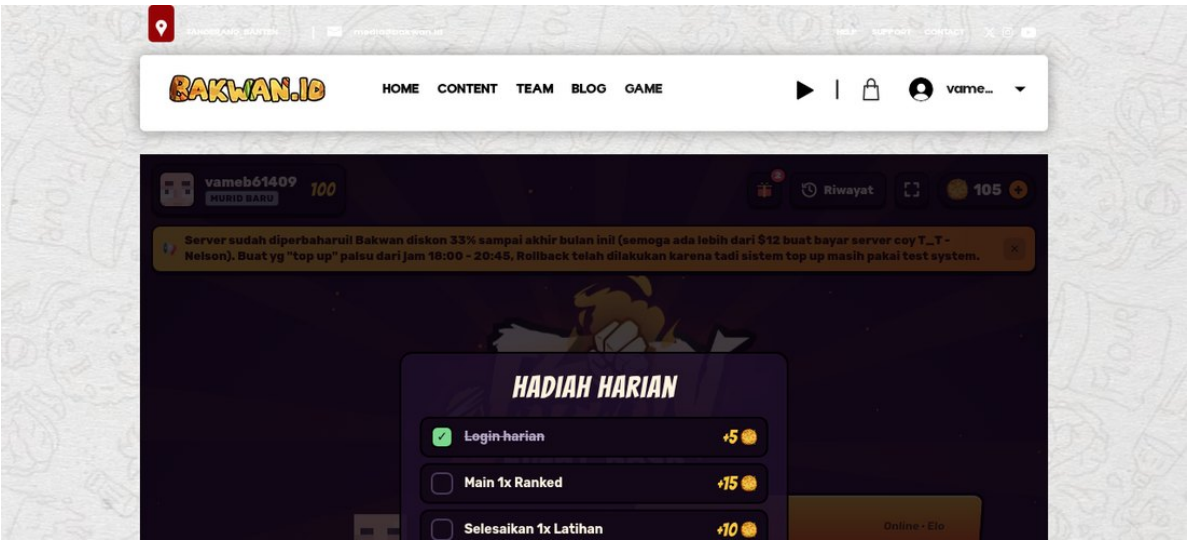


Gambar 25: Profil pemain asli Tyyie: Elo 236 (puncak 268), #442, 51/45/0, winrate 53%, Alana Lv 17, kode teman T9Q8ZH.

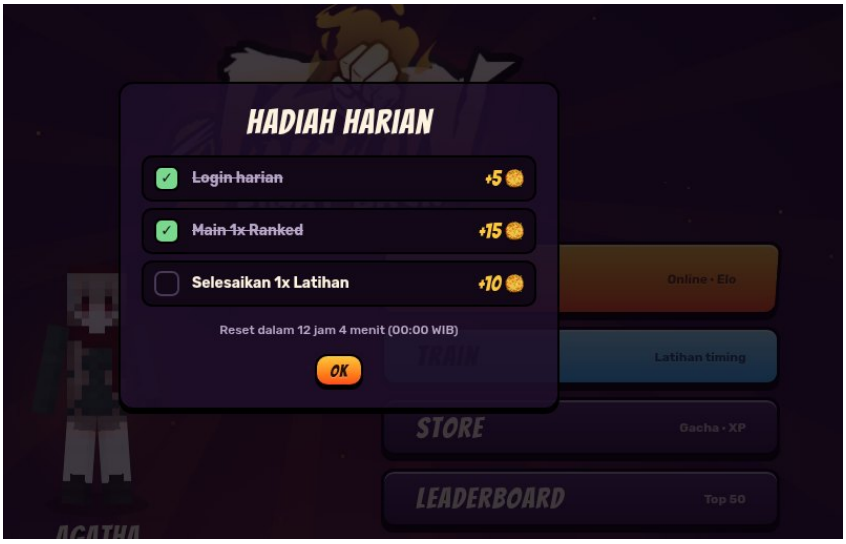
9. Misi Harian, Latihan, dan BUG-09

9.1 Sistem Hadiah Harian Produksi

Ikon hadiah pada bilah atas membuka panel **"Hadiah Harian"** berisi tiga misi: **Login harian +5**, **Main 1x Ranked +15**, dan **Selesaikan 1x Latihan +10**, dengan catatan reset "dalam 12 jam 4 menit (00:00 WIB)". Jumlah hadiah produksi (5/15/10) berbeda dari nilai konfigurasi statis pada kode sumber (1/2/2) — konfigurasi server memang dapat dioverride lewat CMS tanpa publish ulang, dan panitia jelas sudah menaikkan nilai-nilai tersebut. Misi login tercentang otomatis saat login; misi ranked tercentang tepat setelah pertandingan ranked pertama dengan +15 bakwan masuk ke saldo (terverifikasi: 5 → 20).



Gambar 26: Panel Hadiah Harian produksi: Login harian +5, Main 1x Ranked +15, Selesaikan 1x Latihan +10; badge angka menunjukkan sisa misi.



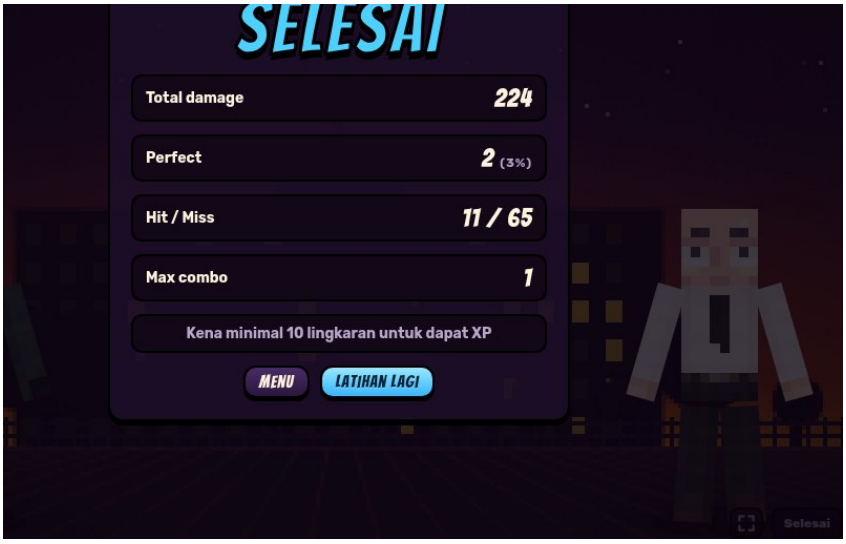
Gambar 27: Setelah ranked: misi "Main 1x Ranked" tercentang dan +15 bakwan masuk; misi latihan masih kosong menunggu 10 hit.

9.2 Latihan: Sesi dengan 11 Hit Tidak Terkredit (BUG-09, Mayor)

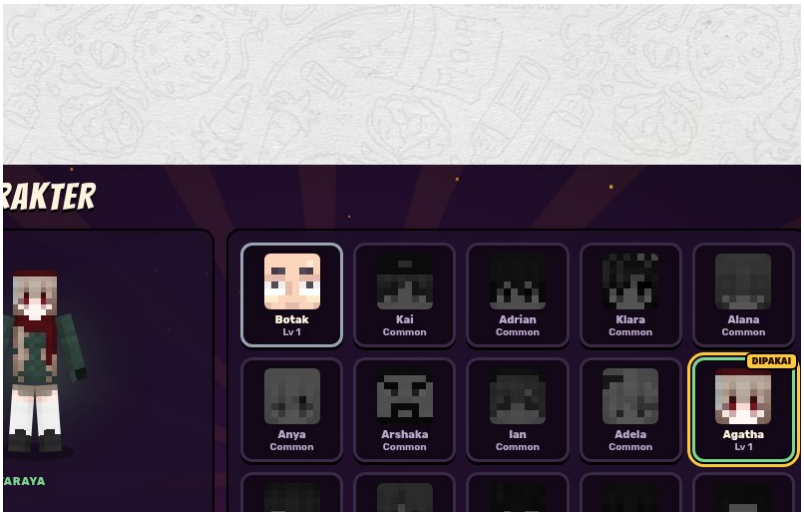
Misi "Selesaikan 1x Latihan" mensyaratkan mengenai minimal 10 lingkaran dalam satu sesi (teks UI: "Kena minimal 10 lingkaran untuk dapat XP"). Karena timing manual sulit bagi otomasi, penguji membangun penjejak piksel yang mendeteksi lingkaran oranye dan cincin penyusutnya lalu memprediksi momen sempurna dari laju penyusutan. Setelah lima sesi, sesi kelima berhasil mencatat **Hit/Miss 11/65** dengan Total damage 224, Perfect 2 (3%), dan combo maksimum 1 — **melampaui syarat 10 hit yang tertulis di layar**.

Namun, layar hasil hanya menampilkan baris "Kena minimal 10 lingkaran untuk dapat XP" — tanpa "XP latihan +10" dan tanpa "Bonus latihan pertama hari ini". Verifikasi lanjutan memperkuat temuan: **XP karakter Agatha tetap 0/100**, saldo bakwan tetap 20, badge misi tetap "1", dan panel Hadiah Harian tetap tidak mencoret misi latihan **bahkan setelah reload halaman penuh**. Analisis kode sumber menunjukkan fungsi server **trainDone()** menolak reward bila **summary.hits** yang diterima di bawah **CONFIG.daily.trainMinHits**, sementara panel admin demo menampilkan nilai bawaan 10 — padahal teks syarat pada UI klien adalah teks statis yang di-hardcode. Pola ini paling konsisten dengan **desinkronisasi konfigurasi**: server produksi memakai ambang yang lebih tinggi dari 10 (atau menghitung hit dengan cara berbeda), sementara seluruh UI — layar hasil, panel admin, dan pesan syarat — tetap mengklaim 10. Ditambah lagi, pemanggil API pada klien dibungkus **catch(e){}** tanpa toast maupun retry, sehingga kegagalan jaringan saat mengirim hasil latihan hilang diam-diam tanpa jejak bagi pemain.

Dampak: pemain yang benar-benar menyelesaikan syarat **kehilangan +10 XP dan +10 bakwan tanpa penjelasan**, misi harian tak bisa diselesaikan (menghalangi koleksi hadiah harian), dan tim dukungan akan dibanjiri laporan "sudah 10 hit tapi tidak dapat reward" yang sulit dideteksi karena tidak ada log kegagalan di sisi klien. Rekomendasi: samakan sumber nilai syarat antara server dan UI (ambil dari CONFIG server, jangan hardcode), kirim ambang efektif ke klien sebagai bagian dari publicConfig, dan ganti catch(e){} dengan penanganan yang menampilkan pesan serta mencatat log.



Gambar 28: BUG-09: layar hasil latihan menampilkan Hit/Miss 11/65 (di atas syarat 10) namun tanpa baris reward XP maupun bonus harian.



Gambar 29: Bukti lanjutan BUG-09: XP karakter Agatha tetap 0/100 setelah sesi 11 hit — reward tidak pernah masuk ke database.

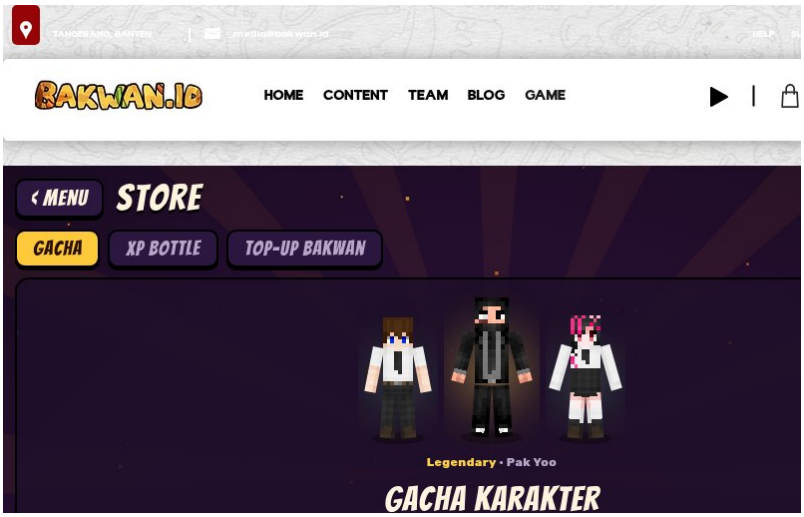
9.3 Catatan Anti-Makro yang Sehat (Bukan Bug)

Sebagai catatan positif: pada sesi-sesi dengan klik acak cepat (26–40 klik dalam sekitar 30 detik), hampir semua klik dihitung miss (misalnya 2/59) — jendela timing ±230 ms dan posisi lingkaran yang acak membuat spam klik tidak produktif. Bot prediksi piksel pun hanya mencetak 2 perfect dari 11 hit. Dengan demikian sistem latihan terbukti **cukup tahan terhadap makro sederhana**; temuan BUG-09 bukan soal anti-cheat, melainkan soal reward yang tidak jatuh meski syarat terpenuhi.

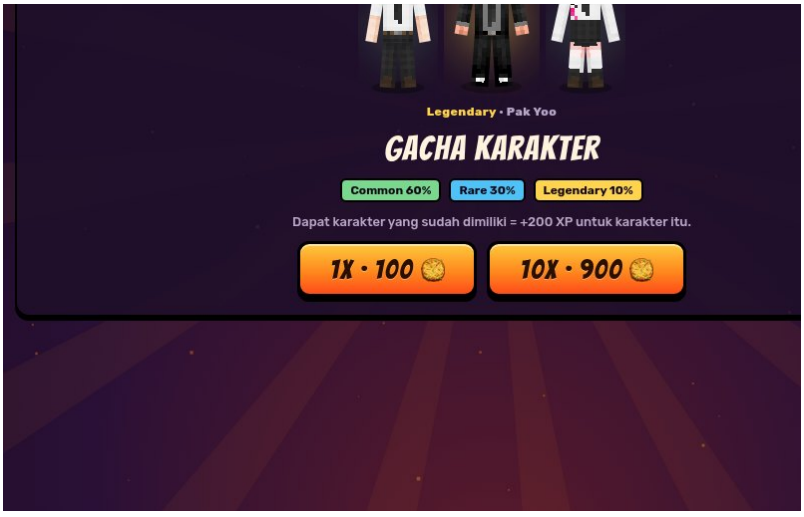
10. Store, Gacha, dan BUG-10 Top-Up Xendit

10.1 Store Produksi: Gacha dan Botol XP

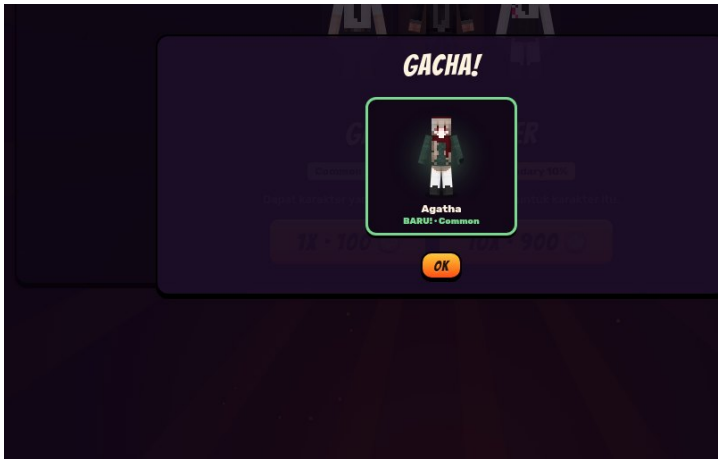
Store produksi terdiri dari tiga tab: **Gacha**, **XP Bottle**, dan **Top-up Bakwan**. Gacha menampilkan tarif terbuka — Common 60%, Rare 30%, Legendary 10% — dengan harga 100 bakwan untuk satu tarik dan 900 untuk sepuluh, serta aturan duplikat “+200 XP untuk karakter itu”. Satu tarikan uji (saldo 105 → 5) menghasilkan karakter **Agatha** — **BARU! · Common** (SMA Pelitaraya, skill Lempar Penghapus + Semangat 45, stat 1000 HP / 40 ATK / 20 DEF) dengan animasi reveal ber-frame dan label “BARU!”. Botol XP dijual 50 bakwan (+100 XP) dan 250 bakwan (+600 XP) dengan pencocokan harga terhadap konfigurasi internal yang tepat. Panel **Ganti Karakter** menampilkan seluruh 25 karakter (1 starter, 10 Common, 7 Rare, 7 Legendary) dengan karakter yang belum dimiliki disembunyikan abu-abu; karakter baru langsung dapat dipakai dan detail skill beserta level bukanya (slot kotak terbuka Lv 10, slot segitiga Lv 20) terbaca jelas.



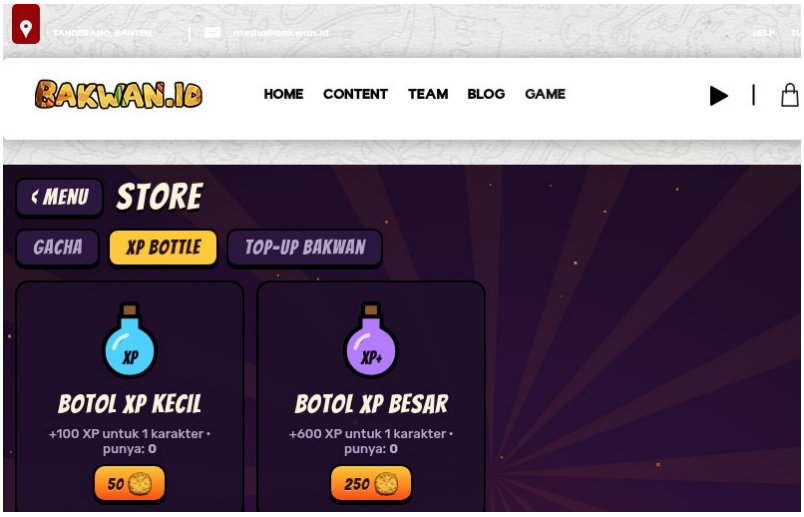
Gambar 30: Store produksi tab Gacha dengan tiga karakter unggulan Legendary dan tab Top-up Bakwan.



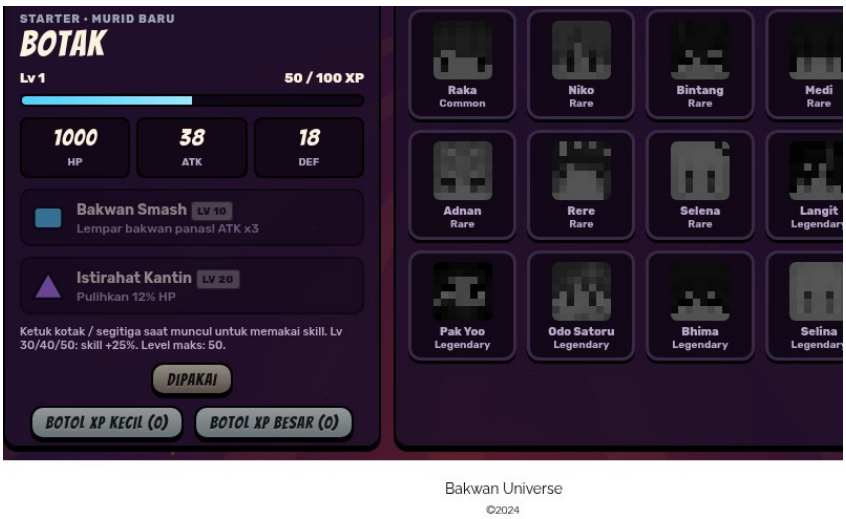
Gambar 31: Tarif gacha terbuka: Common 60%, Rare 30%, Legendary 10%; duplikat menjadi +200 XP.



Gambar 32: Hasil tarikan uji: karakter baru “Agatha — BARU! · Common”; saldo berkurang 100 bakwan.



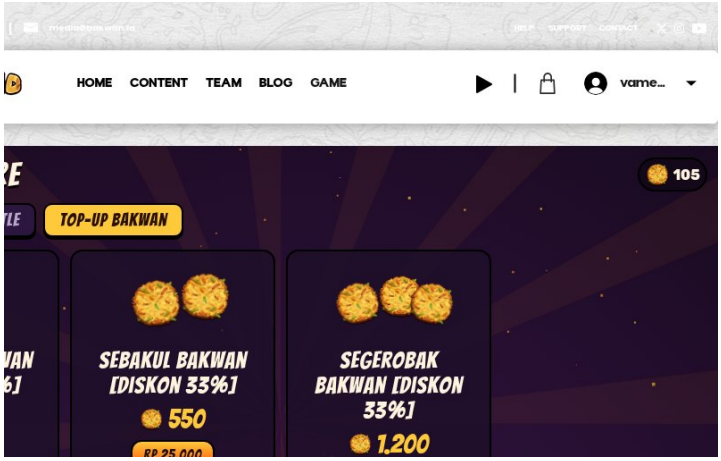
Gambar 33: Tab XP Bottle: Botol XP Kecil (+100 XP, 50 bakwan) dan Botol XP Besar (+600 XP, 250 bakwan).



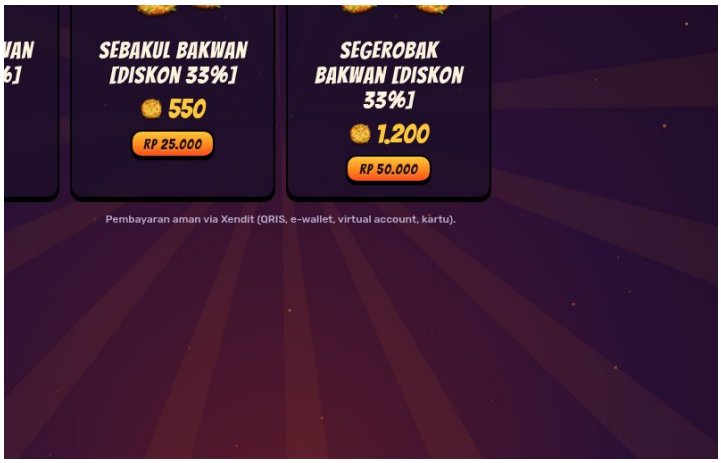
Gambar 34: Panel Ganti Karakter: detail Botak Lv 1 (1000 HP / 38 ATK / 18 DEF), skill beserta level bukanya, dan grid 25 karakter dengan status kepemilikan.

10.2 Harga Top-Up Berdiskon 33%

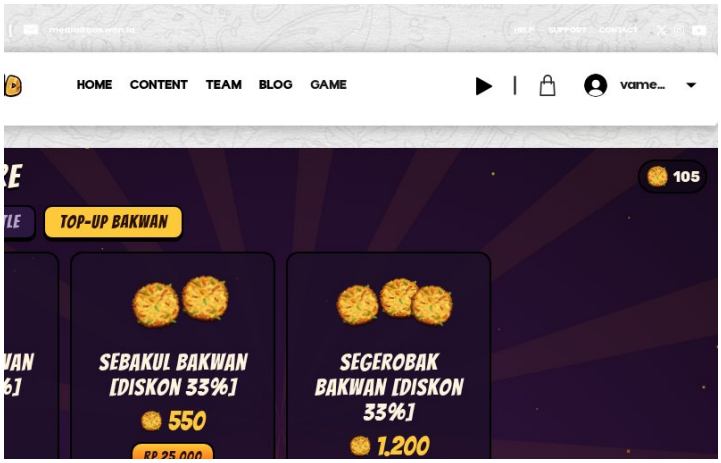
Tab Top-up Bakwan menjual tiga paket — **Sepiring Bakwan 100** (Rp 5.000), **Sebakul Bakwan 550** (Rp 25.000), dan **Segerobak Bakwan 1.200** (Rp 50.000) — semuanya berlabel “Diskon 33%” sesuai pengumuman pengembang, dengan catatan kaki “Pembayaran aman via Xendit (QRIS, e-wallet, virtual account, kartu)”. Berbeda dengan demo ronde pertama yang memakai tombol “BAYAR (DEMO)” sekali klik (BUG-05), alur produksi kini memanggil **createTopup** ke server lalu membuka URL checkout Xendit nyata — perkembangan yang benar arah, meski kini menabrak temuan berikut.



Gambar 35: Halaman Store dibuka dari tombol saldo “bakwan 105 +” dengan tab Top-up Bakwan aktif.



Gambar 36: Paket Sebakul (550 — Rp 25.000) dan Segerobak (1.200 — Rp 50.000) berlabel Diskon 33%, dengan catatan pembayaran Xendit.

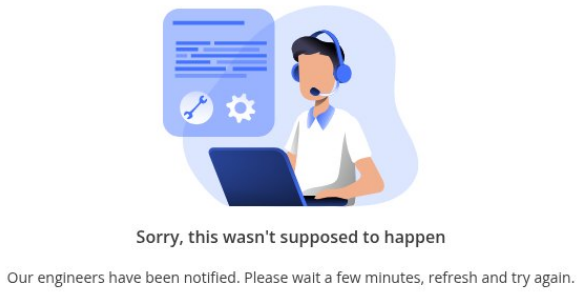


Gambar 37: Seluruh katalog top-up: Sepiring 100 — Rp 5.000, Sebakul 550 — Rp 25.000, Segerobak 1.200 — Rp 50.000.

10.3 BUG-10: Halaman Checkout Xendit Error Permanen (Kritis)

Menekan paket Rp 5.000 membuat server membuat invoice lalu peramban dialihkan ke **checkout.xendit.co/web/6add8704bfd8f0d68bd901a0** — namun halaman itu **gagal merender** dan hanya menampilkan ilustrasi CS dengan pesan **“Sorry, this wasn't supposed to happen — Our engineers have been notified. Please wait a few minutes, refresh and try again.”**. Konsol peramban merekam **AxiosError: Network Error (ERR_NETWORK)** berulang dari aset Xendit. Penundaan 15 detik disertai muat ulang penuh **tidak mengubah apa pun** — error bersifat permanen pada invoice tersebut. Saldo akun tidak bertambah dan tidak ada invoice lain yang dibayar selama pengujian.

Kombinasi bukti — (a) harga yang sudah diiklankan berdiskon 33%, (b) pengumuman rollback top-up palsu karena “masih pakai test system”, (c) checkout live yang error permanen — menunjukkan integrasi pembayaran **belum siap menerima uang nyata**: setiap pemain yang mencoba top-up hari ini akan melihat error dan uang tidak tertagih. Keparahan: ini adalah pintu pendapatan satu-satunya game dan gagal 100% pada langkah terakhir; berpotensi pula menimbulkan keluhan “sudah bayar tapi saldo tidak masuk” apabila sebagian kanal pembayaran ternyata hidup sementara webhook-nya belum benar. Rekomendasi: uji end-to-end satu paket dengan pembayaran sungguhan bernilai kecil, verifikasi callback/webhook signature Xendit di sisi server, tampilkan halaman “pembayaran sedang pemeliharaan” alih-alih membiarkan invoice error terbentuk, dan pantau invoice gagal di dashboard Xendit.

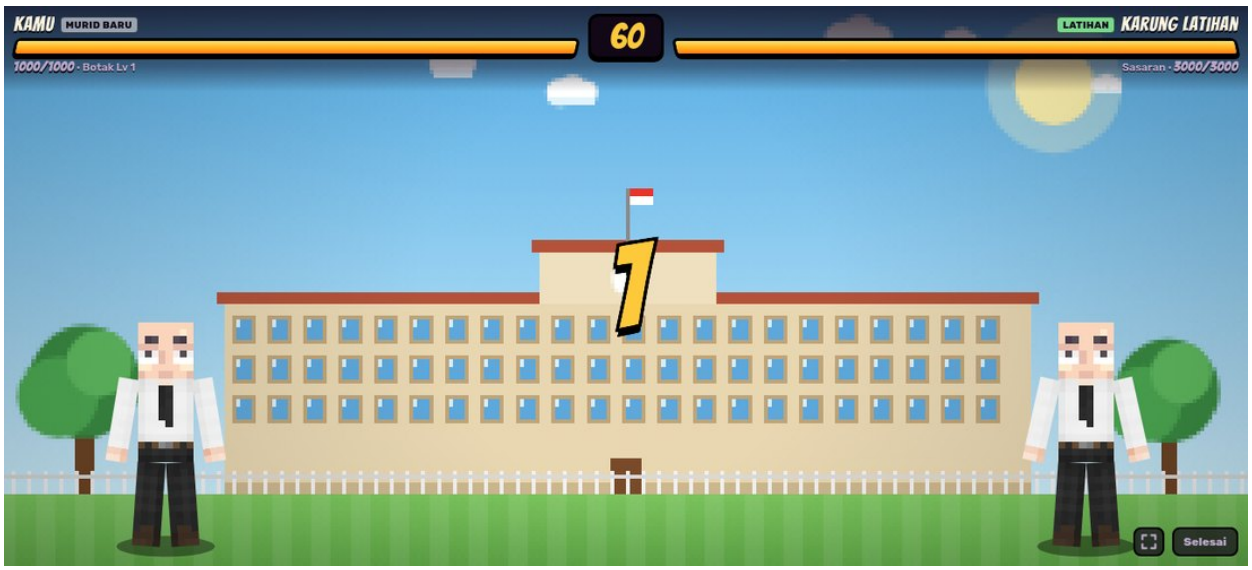


Gambar 38: BUG-10: checkout Xendit untuk invoice 6add8704… gagal dengan “Sorry, this wasn't supposed to happen” — error tetap muncul setelah muat ulang.

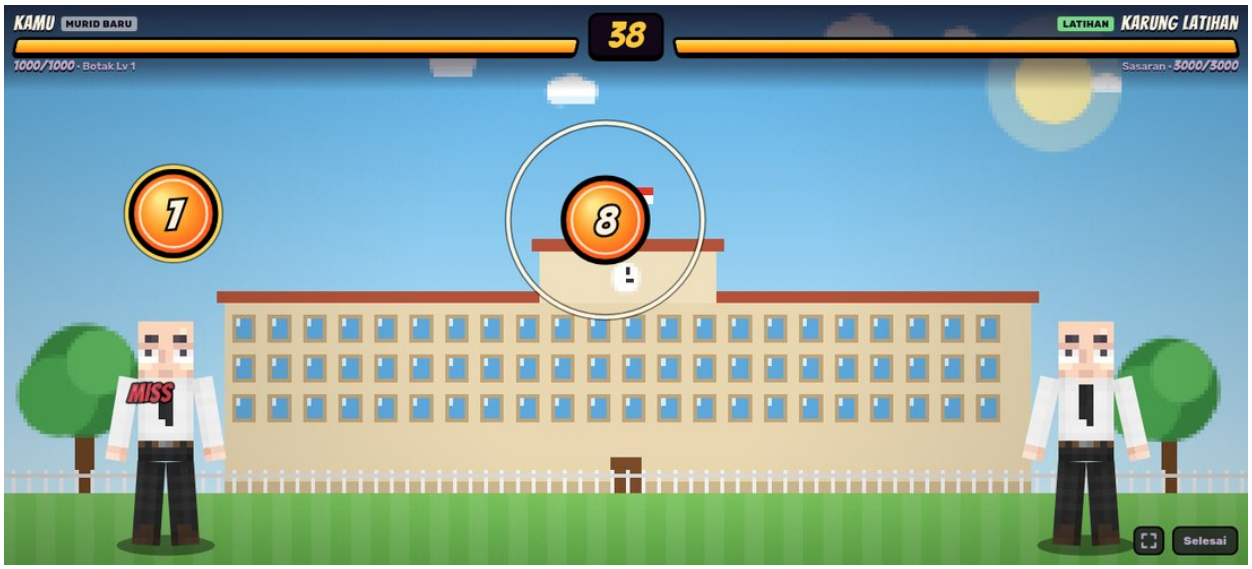
11. Mekanisme dan Cara Bermain

11.1 Konsep Dasar

“Bakwan Fight Back” adalah game duel ritme-timing berlatar komunitas Minecraft Bakwan. Dua karakter saling berhadapan; pemain menerima serangkaian **lingkaran bernomor** yang menyusut menuju cincin target. Klik/ketuk lingkaran tepat ketika lingkaran dalam sejajar dengan cincin untuk mendaratkan pukulan. Semakin presisi timing-nya, semakin besar kerusakan. Kegagalan (miss) membuat lawan — karung latihan, bot, atau pemain lain — memukul balik. Ronde berakhir saat salah satu pihak K.O. atau waktu habis (90 detik untuk ranked, 60 detik untuk latihan).



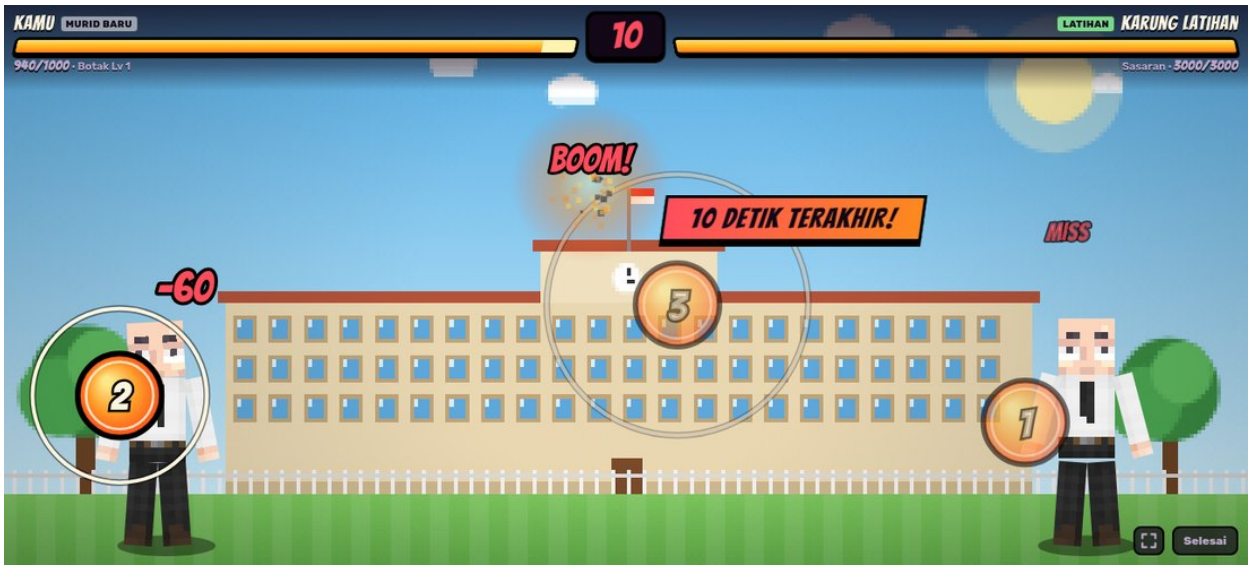
Gambar 39: Awal ronde latihan: hitung mundur 3-2-1-FIGHT, HP pemain 1000, sasaran penuh.



Gambar 40: Gameplay inti: lingkaran bernomor menyusut menuju cincin; MISS muncul bila telat.

11.2 Sistem Timing dan Kerusakan

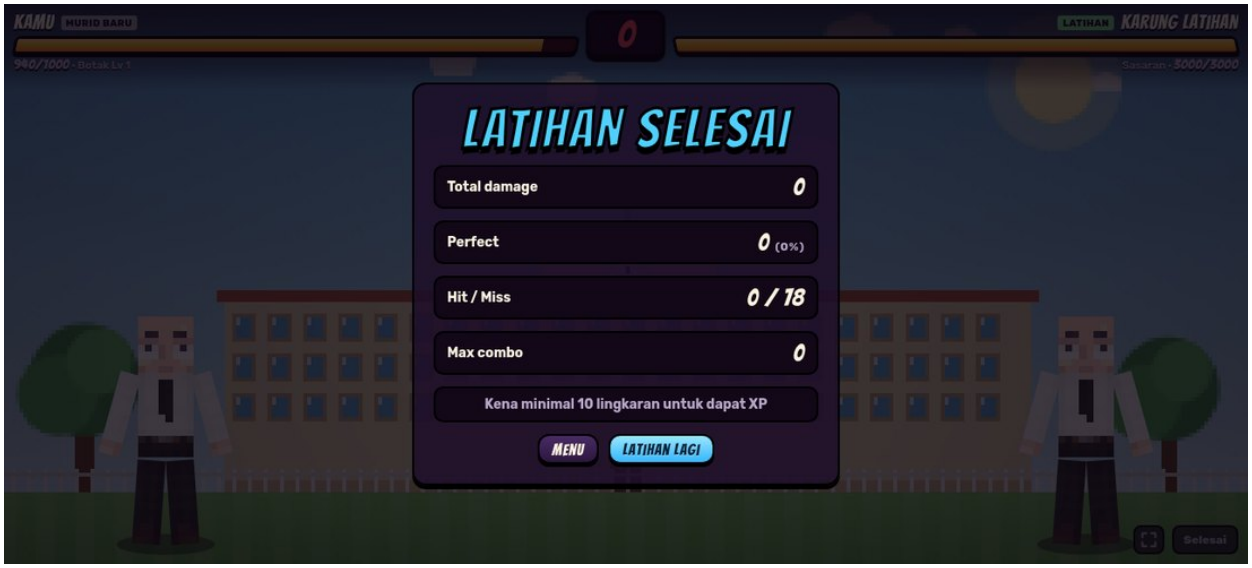
Konfigurasi pada kode menetapkan jendela timing dalam milidetik dari waktu sempurna: **perfect ±70 ms**, **great ±140 ms**, **good ±230 ms**; klik lebih awal dari 450 ms dihitung miss langsung. Pengali kerusakan: perfect 1.0, great 0.75, good 0.5, ok 0.25. Setiap combo menambah +2% kerusakan hingga maksimum +30% (15 combo). Selain lingkaran biasa, terdapat lingkaran **bom** (tanda seru) yang tidak boleh diklik: mengekliknya memicu BOOM dan kerusakan ke diri sendiri.



Gambar 41: Kehilangan timing memicu serangan balik karung (BOOM!, -60 HP).

11.3 Mode Latihan

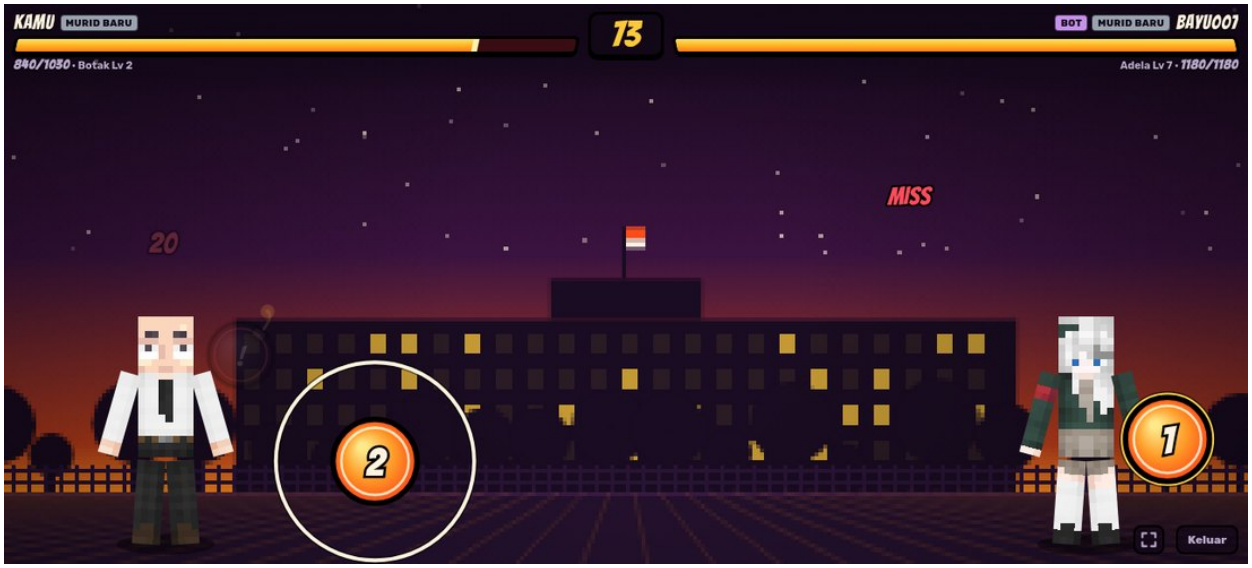
Mode Latihan (“Train - Latihan timing”) berhadapan dengan Karung Latihan yang tidak menyerang kecuali saat pemain miss. Hasil ronde menampilkan total damage, jumlah Perfect, rasio Hit/Miss, dan combo maksimum. Untuk mendapat XP, pemain harus mengenai minimal 10 lingkaran dalam satu ronde (“Kena minimal 10 lingkaran untuk dapat XP”). Ronde latihan berdurasi 60 detik dan dapat diulang tanpa biaya.



Gambar 42: Layar hasil latihan: 0/18 hit pada sesi uji tanpa klik; syarat 10 hit untuk XP.

11.4 Mode Ranked, Elo, dan Bot

Mode Ranked mencari lawan online dengan rentang Elo yang melebar seiring waktu (awal ±150, tumbuh +25/detik hingga ±2500). Bila tidak ada lawan dalam 20 detik, bot dipasangkan (pada demo: 5 detik). Pertandingan memakai seed bersama sehingga kedua klien menghasilkan pola lingkaran yang sama; hit dikirim pemain-ke-pemain melalui relay realtime (Ably) dan divalidasi ulang server Wix. Hasil menang/kalah mengubah Elo dengan K-factor 40 untuk lawan nyata dan 30 untuk bot. Dalam pengujian, kekalahan K.O. dari bot “Bayu007” menurunkan Elo 100 menjadi 87 (-13) serta memberi bonus ranked pertama +2 bakwan dan +25 XP karakter.



Gambar 43: Ranked vs bot Bayu007 (Adela Lv 7): catatan pemain di kiri, catatan bot di kanan.



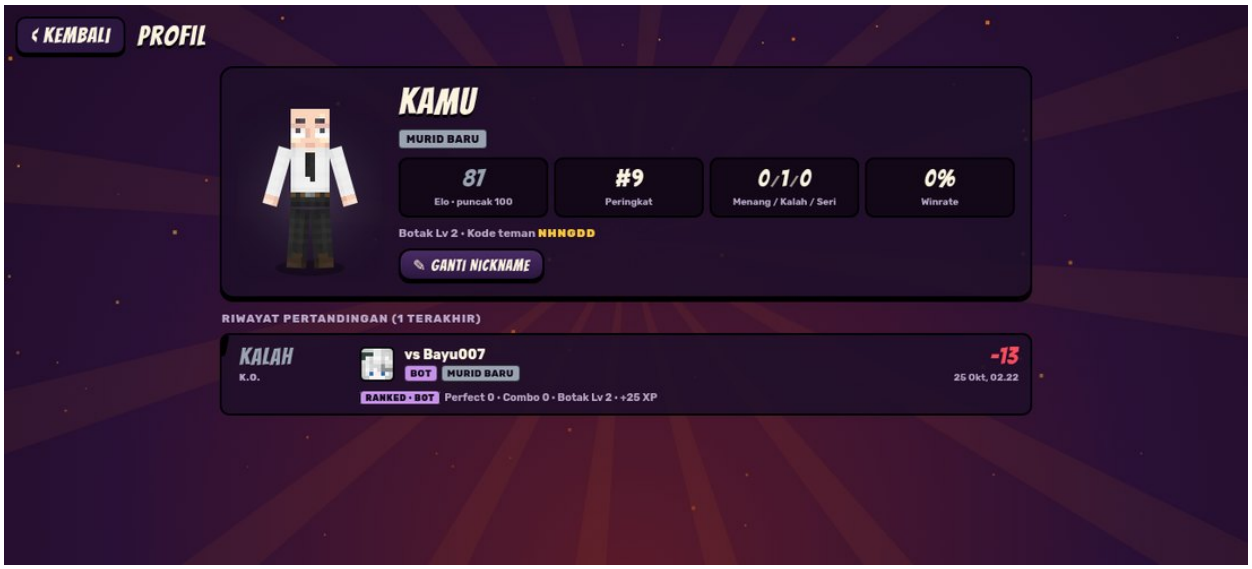
Gambar 44: Lingkaran bom (tanda seru) muncul di sisi lawan; menyentuhnya berarti kerusakan diri.



Gambar 45: Hasil KALAH: K.O. vs Bayu007, Elo turun 13 poin, bonus harian dan XP tetap diberikan.

11.5 Karakter, Skill, dan Progres

Tersedia 25 karakter dalam tiga tingkat kelangkaan (Common/Rare/Legendary), masing-masing dengan HP, ATK, DEF, dan dua skill aktif. Skill diaktifkan dengan mengetuk kotak/segitiga yang muncul saat bertarung; contohnya “Bakwan Smash” (ATK x3) dan “Istirahat Kantin” (pulih 12% HP). Level maksimum 50; batas XP naik per level (contoh: 100 untuk Lv 1 menuju Lv 2, 120 untuk Lv 2 menuju Lv 3). XP diperoleh dari menang/seri/kalah ranked, latihan, duel teman, dan duplikat gacha (+200 XP).



Gambar 46: Profil pemain: rank, Elo, winrate, kode teman, dan riwayat pertandingan.



Gambar 47: Leaderboard Top 50 (mode demo memuat 8 pemain seed + sesi uji).

12. Ekonomi Game, Leaderboard, dan Validasi Input

12.1 Mata Uang, Hadiah Harian, dan XP

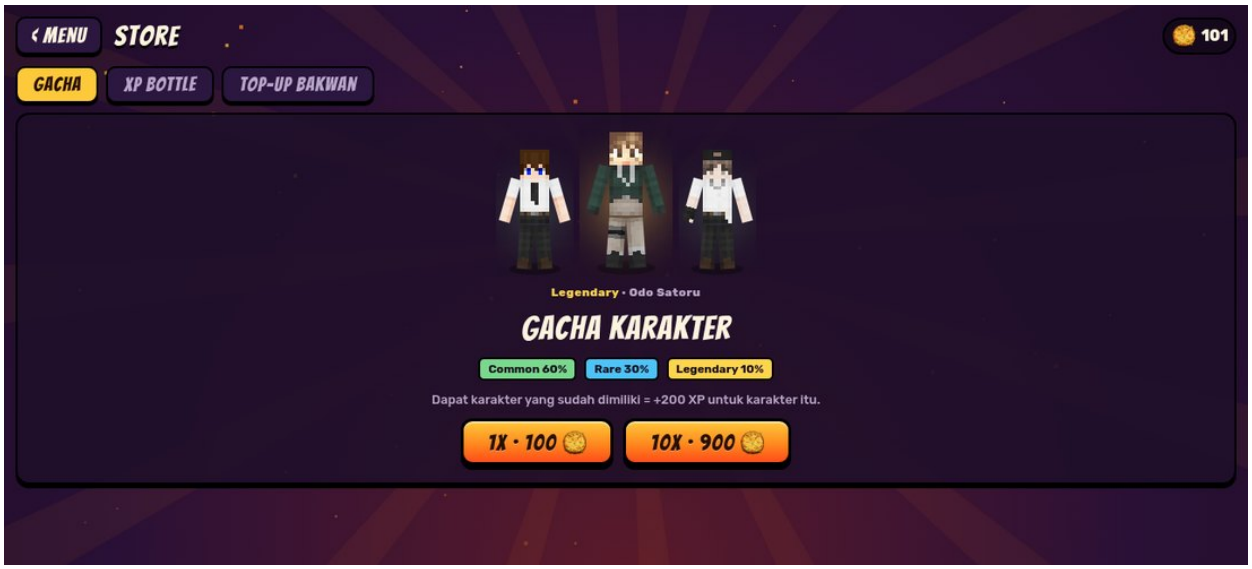
Mata uang dalam game adalah **bakwan**. Pemain baru menerima 100 bakwan (setara satu gacha) — terverifikasi pada akun resmi yang dimulai dengan saldo 105. Nilai hadiah harian pada kode sumber statis adalah +1 untuk login, +2 untuk ranked pertama, dan +2 untuk latihan pertama; namun server produksi ronde kedua memakai nilai yang jauh lebih besar — **+5 / +15 / +10** — membuktikan konfigurasi memang dapat dioverride dari CMS tanpa publish ulang. Seluruh progres hadiah direset pukul 00:00 WIB (terverifikasi dua kali: hitung mundur 14 jam 34 menit pada 09.26 dan 12 jam 4 menit pada 21.22). Botol XP dijual 50 bakwan (+100 XP) dan 250 bakwan (+600 XP). Jejak saldo akun uji konsisten di setiap langkah: 105 → 5 (gacha) → 20 (+15 bonus ranked) dan tetap 20 setelah BUG-09.



Gambar 48: Modal Hadiah Login Harian dengan daftar misi harian dan waktu reset WIB.

12.2 Gacha Karakter

Gacha karakter berbiaya 100 bakwan untuk satu kali tarik atau 900 untuk sepuluh kali, dengan peluang tercantum terbuka: Common 60%, Rare 30%, Legendary 10%. Karakter duplikat dikonversi menjadi +200 XP karakter tersebut. Pada sesi uji, satu tarikan menghasilkan karakter Common baru “Arshaka” dan saldo berkurang 101 menjadi 1.



Gambar 49: Layar Store tab Gacha: tarif kelangkaan terbuka dan dua pilihan tarikan.

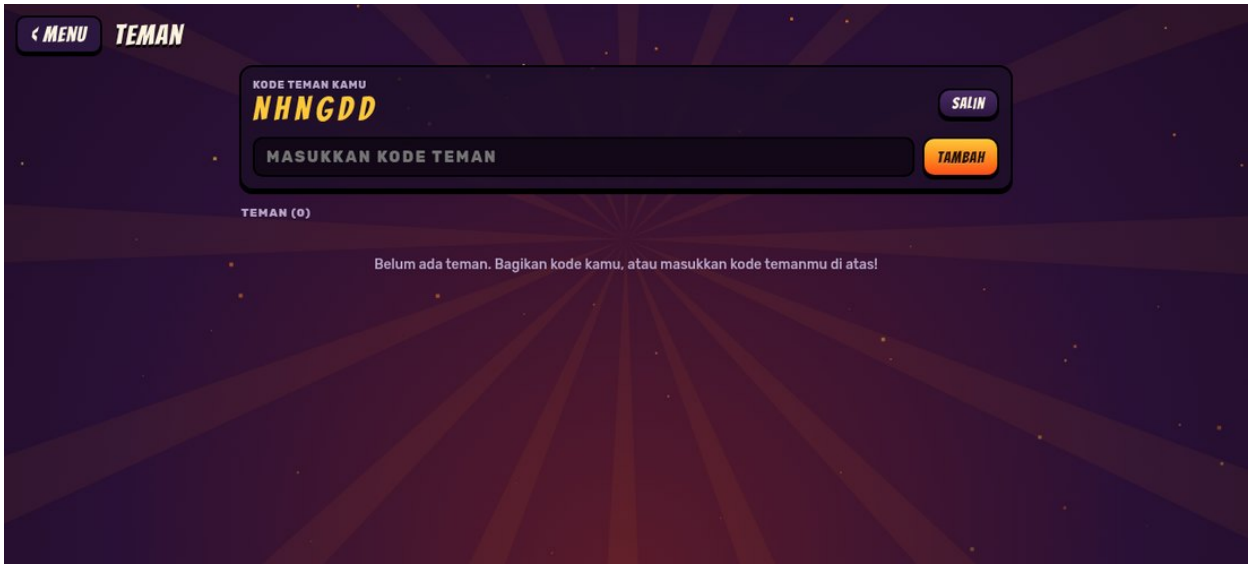


Gambar 50: Hasil gacha uji: karakter Common baru “Arshaka”; saldo 101 menjadi 1.

12.3 Top-Up Uang Nyata

Monetisasi memakai Xendit (QRIS, e-wallet, virtual account, kartu). Pada mode demo, tombol “BAYAR (DEMO)” sekali klik langsung mengkreditkan saldo (BUG-05) — dan pengembang kemudian mengonfirmasi lewat pengumuman bahwa sistem top-up sempat berjalan test dan di-rollback. Pada ronde kedua, alur produksi sudah memanggil createTopup dan membuka invoice Xendit sungguhan, tetapi halaman checkout-nya gagal permanen (BUG-10). Untuk program beta, disarankan menonaktifkan top-up sampai

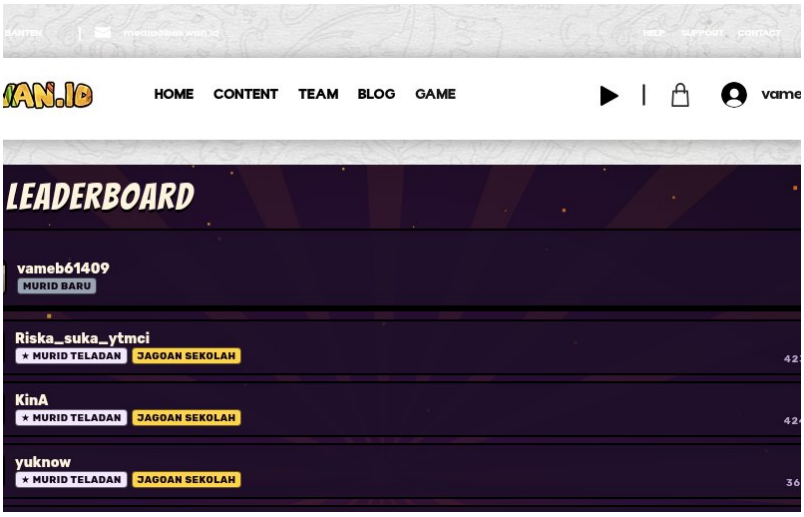
jalur end-to-end terbukti, agar tidak ada dana pemain yang terkunci sebelum ekonomi game stabil. Layar teman (kode teman + duel unranked) dan profil (ganti nickname dengan validasi 3-16 karakter) ditemukan berfungsi normal.



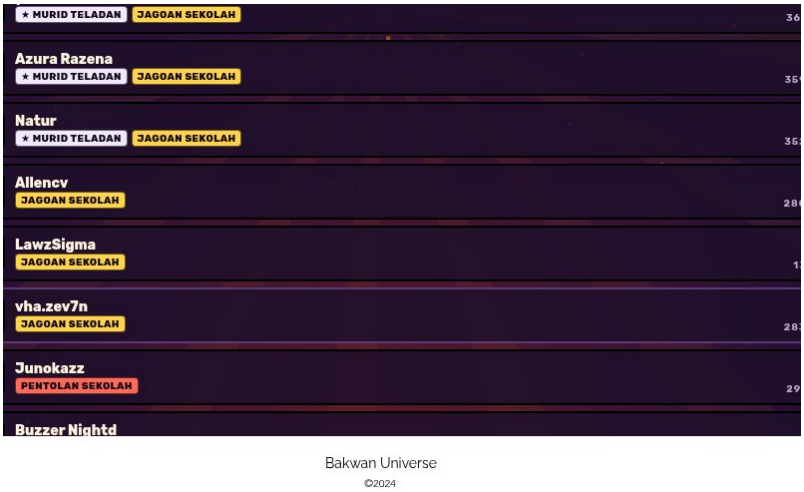
Gambar 51: Layar Teman: kode teman pribadi, salin kode, dan penambahan teman via kode.

12.4 Leaderboard Produksi

Leaderboard produksi menampilkan Top 50 pemain dengan Elo tertinggi. Puncak papan ditempati **Riska_suka_ytmci** (Elo ±42xx) dan **KinA** (±42xx), disusul yuknow (±36xx), Azura Razena, Natur, Allencv, LawzSigma, yha.zev7n — seluruhnya berganda tag “Jagoan Sekolah” (Elo 2001+) dan lima teratas mendapat tag otomatis “Murid Teladan” (sesuai konfigurasi teladan.top=5, minWins=1). Baris akun uji sendiri disematkan khusus di atas daftar agar selalu terlihat tanpa harus scroll. Kehadiran puluhan pemain dengan Elo 2000+ menandakan ladder sudah terisi intensif sejak beta dibuka.



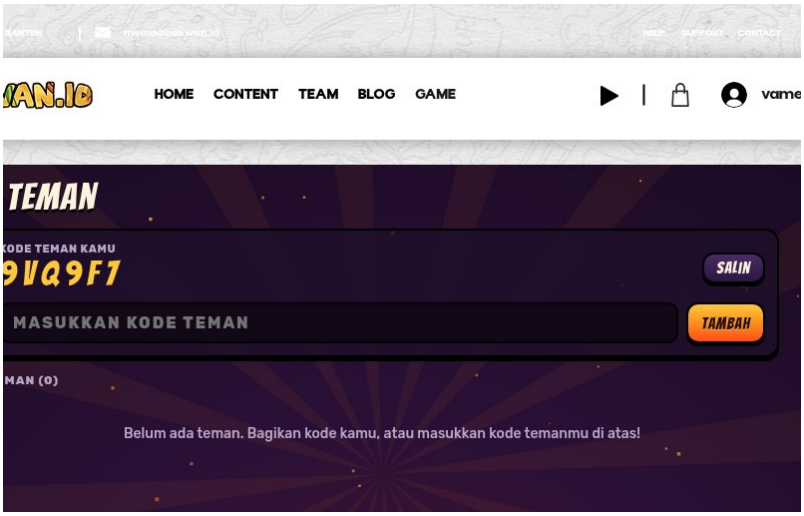
Gambar 52: Leaderboard produksi: baris akun uji tersemat di atas, disusul Riska_suka_ytmci, KinA, dan yuknow dengan tag Murid Teladan + Jagoan Sekolah.



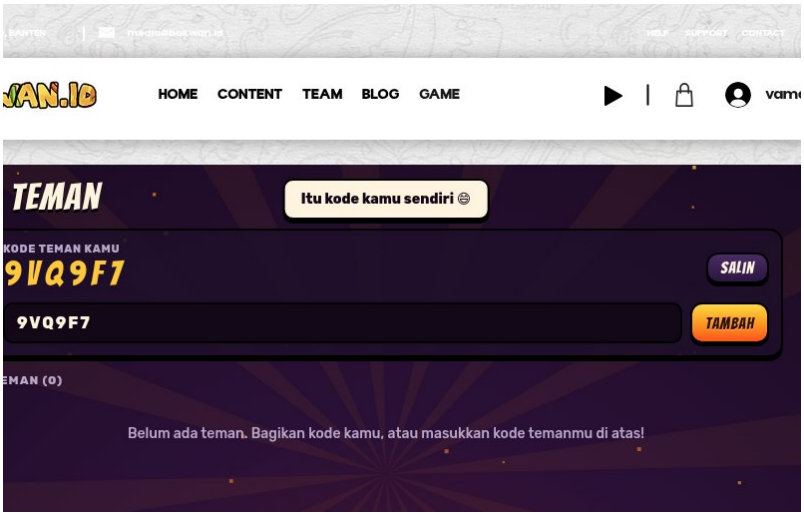
Gambar 53: Bagian bawah Top 50: Allencv, LawzSigma, yha.zev7n, Junokazz (Pentolan Sekolah), dst.

12.5 Uji Validasi: Kode Teman dan Nickname

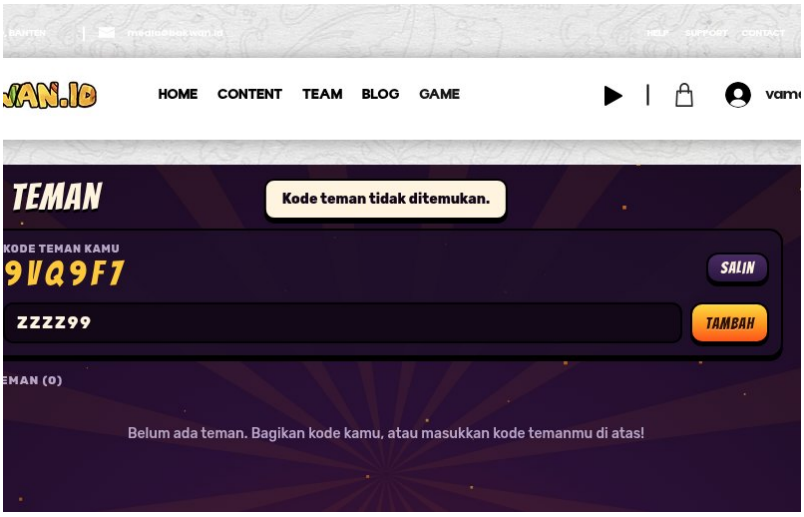
Dua uji batas dilakukan pada panel Teman dengan akun resmi. Menambahkan kode sendiri (9VQ9F7) ditolak dengan toast ramah “Itu kode kamu sendiri”, dan kode tidak valid “ZZZZ99” ditolak dengan “Kode teman tidak ditemukan.” — keduanya sesuai error map internal (SELF_FRIEND, NO_SUCH_CODE). Modal Ganti Nickname menyaring input di sisi klien (minimal 3 karakter, karakter yang diizinkan huruf/angka/spasi/_ . -) dan server melakukan validasi identik (NAME_LENGTH, NAME_CHARS); input panjang dibatasi maxlength=16 pada input HTML. Tidak ditemukan celah bypass pada kedua alur tanpa pengujian invasif.



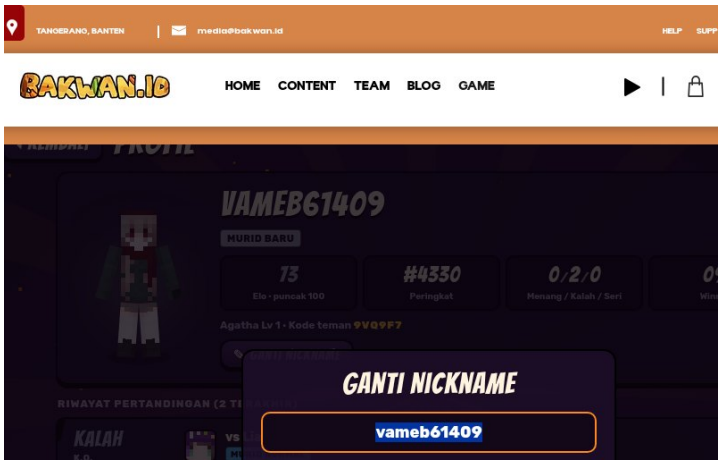
Gambar 54: Panel Teman produksi: kode teman pribadi 9VQ9F7 dengan tombol salin dan input tambah teman.



Gambar 55: Uji validasi 1: menambahkan kode sendiri ditolak dengan "Itu kode kamu sendiri".



Gambar 56: Uji validasi 2: kode "ZZZZ99" ditolak dengan "Kode teman tidak ditemukan."



Gambar 57: Modal Ganti Nickname dengan petunjuk syarat 3–16 karakter dan batas input 16.

13. Rekomendasi Perbaikan

ID	Rekomendasi	Prioritas
BUG-01	Turunkan ambang reCAPTCHA untuk pendaftaran (mis. reCAPTCHA v3 bermata rendah atau v2 invisible), perpendek jumlah ronde maksimum, dan panjang umur sesi tantangan. Berikan pesan kesalahan yang menenangkan serta tombol “coba tantangan baru” tanpa mengulang seluruh form. Pantau tingkat keberhasilan pendaftaran sebagai metrik.	Segera
BUG-02	Selaraskan kebijakan: bila demo memang disengaja, tampilkan badge “MODE DEMO” di halaman bakwan.id/game dan beri tautan resmi “coba demo tanpa akun”; bila tidak, pindahkan pemeriksaan sesi ke dalam aplikasi game (cepat via pesan Bridge ke induk Wix) sehingga URL langsung tidak lagi memainkan demo senyap.	Segera
BUG-03	Jangan pernah menaruh isAdmin=true pada klien. Hilangkan tombol dan rute admin pada build publik/demo (tree-shaking), dan tampilkan halaman 404/403 untuk semua fungsi admin di mode demo. Tambahkan gerbang kata sandi kedua untuk panel admin produksi serta audit log yang wajib terisi.	Segera
BUG-04	Redaksi data sensitif di panel admin (email, kode teman), batasi kolom sesuai kebutuhan tugas, dan pisahkan label tegas antara data seed/demo dan data produksi.	Sebentar lagi
BUG-05	Pisahkan mata uang demo (mis. d-bakwan), nonaktifkan tombol BAYAR (DEMO) di build produksi, dan wajibkan verifikasi tanda tangan webhook Xendit sebelum kredit saldo.	Sebentar lagi
BUG-06	Bulatkan statistik ATK/DEF ke bilangan bulat pada UI.	Rendah
BUG-07	Sinkronkan HP sasaran latihan antara konfigurasi kode dan tampilan UI.	Rendah
BUG-08	Ubah izin halaman Wix Members “/account-settings” menjadi “All members” dari editor (tidak butuh kode), lalu uji ulang tautan menu akun. Pastikan opsi penghapusan akun mandiri tersedia sebagaimana dijanjikan program beta.	Sebentar lagi
BUG-09	Samakan sumber nilai trainMinHits antara server dan seluruh UI (layar hasil, pesan syarat, panel admin) — kirim nilai efektif lewat publicConfig alih-alih hardcode. Ganti catch(e){} pada endTrain() dengan toast kesalahan + log, dan audit trail untuk kasus reward ditolak agar tim dukungan bisa memverifikasi klaim pemain.	Segera
BUG-10	Uji end-to-end satu paket top-up dengan pembayaran nyata bernilai kecil; verifikasi webhook/signature Xendit di server; selama belum lolos, sembunyikan tombol top-up atau tampilkan halaman pemeliharaan alih-alih membiarkan invoice error terbentuk; pantau invoice gagal di dashboard Xendit dan sampaikan status jujur di pengumuman.	Segera

Tabel 2: Rekomendasi perbaikan berdasarkan prioritas.

14. Kronologi Pengujian dan Catatan Penutup

14.1 Kronologi Ringkas

Waktu (WIB)	Kegiatan	Hasil
24 Okt, malam	Rekon situs bakwan.id: home, blog, kategori “Bakwan: Fight Back”	Konteks program didapat; tidak ada pos bug bounty terpublikasi di blog
25 Okt, 00.20	Persiapan temp mail (mail.tm) dan pembukaan halaman game	Email uji siap; gerbang login teridentifikasi
25 Okt, 00.30-01.15	Enam sesi pendaftaran email beserta penyelesaian tantangan reCAPTCHA multi-ronde	BUG-01: seluruh sesi berakhir “challenge expired”
25 Okt, 01.20	Ekstraksi URL iframe game dan pembukaan langsung	BUG-02: mode demo terbuka tanpa akun
25 Okt, 01.25-01.40	Eksplorasi menu demo: Admin, Pemain, Pengaturan, Log	BUG-03/04: panel admin penuh tanpa autentikasi; tidak ada perubahan disimpan
25 Okt, 01.45-02.30	Gameplay latihan 2 ronde, ranked 1 ronde vs bot, gacha 1x, pembelian botol XP, top-up demo, uji nickname & kode teman	Mekanisme terdokumentasi; BUG-05/06 terkonfirmasi; BUG-07 tercatat
25 Okt, 02.35	Verifikasi akhir inbox temp mail dan pembersihan	Inbox kosong; tidak ada akun terbuat sehingga tidak ada akun untuk dihapus
25 Okt, 04.15	Pengembang melaporkan demo hanya uji; akun resmi disediakan (vameb61409)	Ronde 2 dimulai: login sukses tanpa captcha dalam satu percobaan
25 Okt, 04.25-04.45	Dua match ranked produksi vs pemain asli (Tyyie, Lia__multifandom), verifikasi profil lawan, riwayat, dan matematika Elo	Elo 100→86→73 konsisten K=40; bonus ranked +15 bakwan masuk; BUG-08 ditemukan (Pengaturan Akun diblokir paywall)
25 Okt, 20.45-21.10	Store produksi: gacha 1x (Agatha Common baru), inspeksi XP bottle dan katalog top-up diskon 33%	Saldo 105→5→20 konsisten; harga top-up terverifikasi
25 Okt, 21.10-21.20	Uji top-up Rp 5.000: invoice Xendit dibuat lalu dibuka	BUG-10: checkout error permanen “Sorry, this wasn't supposed to happen”; ERR_NETWORK di konsol
25 Okt, 21.22-21.50	Lima sesi latihan dengan penjejak piksel (target misi 10 hit)	BUG-09: sesi 11/65 hit tidak menggrant XP/misi; verifikasi setelah reload
25 Okt, 21.50-22.05	Uji validasi kode teman (sendiri + invalid), modal nickname, leaderboard produksi, dan verifikasi ulang BUG-02/BUG-03 di build terbaru	Validasi bekerja; leaderboard real (puncak Elo ±42xx); BUG-02/03/04 masih hidup
25 Okt, 05.30-06.10	Ronde 3 dibuka: produksi gagal boot total; 3 reload + berkali-kali “Coba lagi”; build lama & baru sama-sama gagal	BUG-11: WD_SCHEMA_DOES_NOT_EXIST (≈1 jam downtime global); demo tetap jalan

Waktu (WIB)	Kegiatan	Hasil
25 Okt, 06.13	Produksi pulih — build baru 20261025-130337 via play.bakwan.id + server WS dedicated; bootstrap diekstrak	Arsitektur baru terdokumentasi; dailies naik 5/15/10; 25 karakter; banner diskon 33%
25 Okt, 06.20-06.40	Validasi bot sempurna di demo (73/73 perfect) lalu produksi: latihan 80/80 perfect (3.594 dmg) + daily +10 bakwan	BUG-12 PoC: BFB_DEBUG memungkinkan bot sempurna; server menerima hit via jalur aksi resmi
25 Okt, 06.45-07.05	14 probe API: gacha (7 varian), buyItem/useItem negatif, trainDone palsu, selectChar legendary, demoPay, creditPurchase, 6 fungsi admin	37/37 probe ditolak bersih (server baru hardened); demoPay NO_FN; admin NOT_ADMIN
25 Okt, 06.50	Retest top-up Rp 5.000 sampai langkah invoice (tanpa membayar)	BUG-10 PERBAIKAN: invoice bfb-mvngxvaj65cdx8 terbit mulus via Xendit
25 Okt, 06.55-07.10	16 match ranked produksi dengan bot (24–32 perfect/match)	10W/8L, Elo 39→165 puncak; kemenangan terbukti TIDAK membayar bakwan (saldo tetap)
25 Okt, 07.15-07.30	Analisis ekonomi gacha + screenshot bukti final (profil, leaderboard #946, halaman Karis, toko)	Karis ≈70 tarikan ≈6.300–7.000 bakwan ≈233 hari dailies — tidak terjangkau tanpa top-up; laporan diperbarui

Tabel 3: Kronologi pengujian 24-25 Oktober 2026 (tiga ronde).

14.2 Kebersihan Pengujian

Sesuai permintaan penyelenggara bahwa akun dapat dihapus setelah pengujian, kami menegaskan: **tidak ada akun yang berhasil dibuat** karena seluruh sesi pendaftaran terhalang BUG-01, sehingga tidak ada data akun yang perlu dihapus. Alamat temp mail bakkyo1lx30lbw@maxxspace.com diverifikasi kosong tanpa surat konfirmasi apa pun, dan dapat dibiarkan kedaluwarsa dengan aman. Tidak ada perubahan yang disimpan pada panel admin demo, tidak ada saldo/pemain nyata yang tersentuh, dan seluruh interaksi terhadap server produksi terbatas pada permintaan baca normal sebagaimana peramban pengunjung biasa.

Untuk ronde kedua: akun resmi **vameb61409@hiringview.com adalah milik penyelenggara dan sengaja tidak dihapus/dilogout permanen**. Perubahan yang terjadi pada akun selama audit — seluruhnya hasil gameplay normal dan dapat diverifikasi di riwayat — adalah: dua kekalahan ranked (Elo 100 → 73, rekor 0/2/0), satu tarikan gacha (karakter baru Agatha), saldo bakwan 105 → 20, tiga misi harian (login +5, ranked +15; latihan tidak terkredit karena BUG-09), serta satu invoice Xendit Rp 5.000 yang dibuat namun **tidak pernah dibayar** (checkout error; invoice akan kedaluwarsa sendiri). Tidak ada pesan tantangan yang dikirim ke pemain lain dan tidak ada data pemain lain yang diubah.

Untuk ronde ketiga, perubahan akun adalah: 15 match ranked dengan bot sempurna (rekor menjadi 10W/8L/0D; Elo puncak baru **165**), satu sesi latihan 80 perfect (Agatha Lv 6), saldo bakwan 20 → 30 murni dari hadiah harian latihan, satu invoice Xendit Rp 5.000 dibuat untuk verifikasi BUG-10 dan **sengaja tidak dibayar** (kedaluwarsa otomatis 24 jam), tidak ada tarikan gacha (saldo tidak cukup — 30 < 100), nickname, teman, dan tantangan tidak disentuh, dan tidak ada data pemain lain yang dibaca maupun diubah. Seluruh

probe API dijalankan hanya dengan kredensial akun uji sendiri, tanpa payload destruktif, tanpa broadcast, dan tanpa beban berulang ke server.

14.3 Penutup

Bakwan Fight Back merupakan paket game beta yang mengesankan untuk ukuran komunitas: satu berkas HTML ringan dengan sistem timing yang menantang, ekonomi gacha yang transparan, matchmaking Elo, relay realtime, hingga panel operasional yang lengkap. Audit ronde kedua dengan akun resmi justru menambah sisi positif yang layak diapresiasi: matchmaking ranked nyata berjalan cepat dengan ladder yang sehat (ribuan pemain terperingkat, puluhan pemain Elo 2000+), matematika Elo terverifikasi presisi, misi harian dan bonus ranked mengalir benar, validasi input tahan banting, dan anti-makro latihan bekerja efektif. Ronde ketiga menambahkan apresiasi yang jauh lebih besar lagi: dalam hitungan jam setelah laporan ronde kedua, pengembang memigrasikan seluruh game ke subdomain dan server WebSocket khusus, membangun ulang sistem battle/Elo, menaikkan hadiah harian, **memperbaiki BUG-10 secara verifikasi**, dan menghadirkan server baru yang menolak seluruh 14 probe manipulasi API dengan bersih — tingkat kegesitan yang jarang dijumpai pada program bug bounty mana pun.

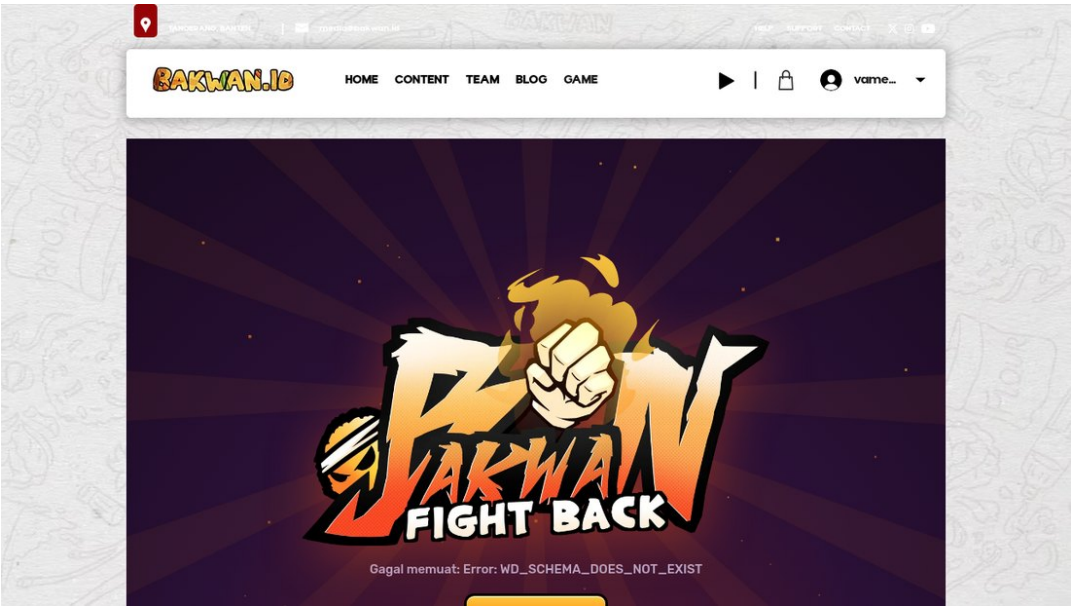
Di sisi lain, ronde kedua menyingkap dua masalah yang paling menyakitkan secara bisnis: pintu pendapatan (top-up Xendit) gagal 100% pada langkah terakhir (BUG-10), dan reward progresi yang dijanjikan UI tidak pernah jatuh (BUG-09) — ditambah BUG-08 yang menutup akses member ke pengaturan akunnya sendiri. Ronde ketiga menambahkan dua kekhawatiran baru yang lebih strategis: **rentan waktu henti produksi** saat migrasi (BUG-11) dan **hook debug klien yang menjadikan bot sempurna trivial** (BUG-12) — mengancam integritas ladder ranked dan nilai eksklusif karakter Legendary, ditambah ekonomi gacha yang secara matematis menutup akses karakter target bagi pemain non-top-up (≈233 hari pengumpulan). Kedua temuan kritis ronde pertama (bypass gerbang dan paparan panel admin demo) juga masih hidup. Dengan menutup lima temuan kritis — loop captcha, bypass gerbang, paparan admin, checkout pembayaran (✓ selesai), dan downtime migrasi (pulih) — serta memagari hook debug dan menyeimbangkan ekonomi gacha, game ini siap diuji luas ke komunitas Bakky dengan risiko yang jauh lebih terkendali. Kami siap membantu verifikasi ulang setelah perbaikan dirilis.

15. Ronde 3: Migrasi Server, Bot Sempurna, dan Ekonomi Gacha (25 Okt 2026)

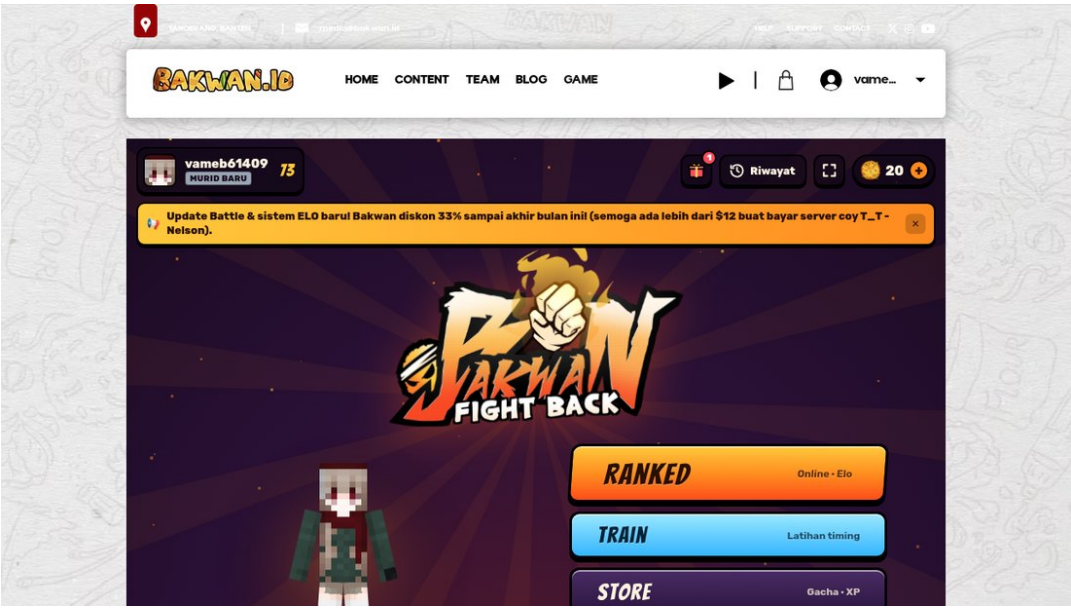
Ronde ketiga dilaksanakan dengan instruksi khusus dari penyelenggara: BUG-08 dan BUG-10 sedang dikerjakan, BUG-09 dinyatakan berjalan sesuai desain, dan penguji diminta **memainkan game sampai memperoleh karakter Legendary "Karis"** sekaligus menguji logika gacha, dengan saran agar ranked diprioritaskan karena "uang" bakwan bisa diperoleh dari latihan atau ranked. Ronde ini dilakukan dengan akun resmi yang sama (vameb61409) pada build baru **20261025-130337** dan menutup seluruh misi tersebut dengan temuan yang jauh lebih dalam dari sekadar bug: sebuah peristiwa downtime, satu celah klien berdampak kompetitif, bukti empiris pengerasan server, dan analisis ekonomi yang menunjukkan karakter target secara realistis tidak terjangkau tanpa top-up uang riil.

15.1 BUG-11 (Kritis): Downtime Produksi — WD_SCHEMA_DOES_NOT_EXIST

Pada awal sesi (sekitar pukul 05.30–06.10 WIB), halaman game produksi gagal boot total: setelah logo, layar menampilkan pesan **"Gagal memuat: Error: WD_SCHEMA_DOES_NOT_EXIST"** dengan tombol "Coba lagi" yang selalu gagal. Error ini adalah kode galat Wix Data yang berarti **skema koleksi basis data yang diminta tidak ada** — konsisten dengan pengembang yang sedang membangun/memigrasi data di tengah perbaikan BUG-08/BUG-10. Kegagalan bersifat persisten (3 kali reload halaman penuh + berkali-kali klik "Coba lagi" selama ≈ 40 menit) dan **menimpa kedua build** (build lama 8756bf... maupun build baru yang sedang digulirkan), sehingga seluruh pemain tidak dapat bermain pada rentang waktu tersebut. Menariknya, mode demo tetap berjalan normal karena tidak menyentuh backend — memperlihatkan pemisahan jalur demo/produksi yang memang dirancang. Game pulih sendiri sekitar pukul 06.13 WIB ketika build baru selesai digulirkan. Gambar 58 dan 59 menunjukkan kondisi gagal boot tersebut.



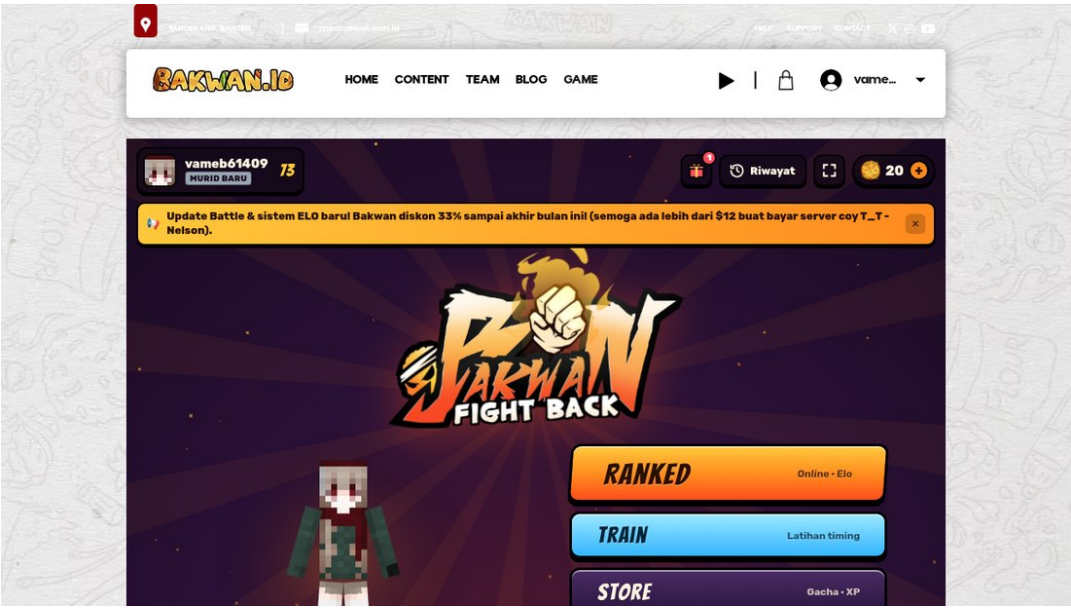
Gambar 58: Layar gagal boot produksi: WD_SCHEMA_DOES_NOT_EXIST (BUG-11).



Gambar 59: Produksi pulih pukul 06.13 WIB — menu utama build baru dengan banner pengumuman update.

15.2 Migrasi Infrastruktur: play.bakwan.id dan Server WebSocket Dedicated

Bersamaan dengan pemulihan, terdeteksi perubahan arsitektur yang sangat besar: iframe game kini memuat **https://play.bakwan.id/game.html** (subdomain khusus game) menggantikan berkas statis filesusr.com, dan seluruh trafik API berpindah ke **server WebSocket dedicated wss://play.bakwan.id/ws** yang berjalan di luar Wix. Pengumuman di dalam game menegaskan konteksnya: "**Update Battle & sistem ELO baru! Bakwan diskon 33% sampai akhir bulan ini (semoga ada lebih dari $12 buat bayar server coy T_T - Nelson)**" — sebuah kejujuran biaya infrastruktur yang patut diapresiasi. Perubahan yang terverifikasi pada build baru antara lain: hadiah login harian baru (modal "Hadiah Login Harian!"), besaran hadiah harian dinaikkan dari 1/2/2 menjadi **5 (login) / 15 (ranked pertama) / 10 (latihan pertama) bakwan per hari**, syarat hit latihan dinaikkan 10 → **20**, konfigurasi server kini menyertakan 25 karakter (11 common, 7 rare, 7 legendary) dengan Karis ber-ID internal "beaconcream", serta mode latihan baru dengan target damage 5.000 dan bom berjadwal (13–14 bom per sesi 60 detik, damage 6% HP sendiri). Panel admin mode demo juga membawa kontrol yang lebih luas (termasuk pengaturan peluang gacha, bom, dan Elo) — BUG-03/04 masih hidup di sisi demo, namun ACL sisi server tetap solid (lihat 15.5).



Gambar 60: Banner pengumuman update battle/Elo + diskon 33% di build baru.



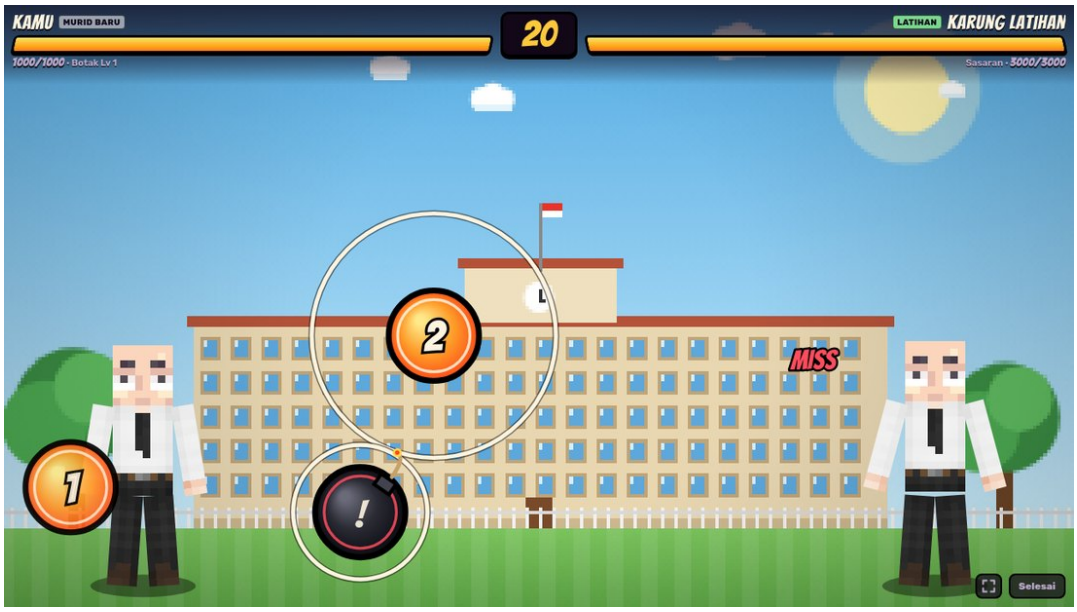
Gambar 61: Fitur baru: modal Hadiah Login Harian di build 20261025-130337.

15.3 BUG-12 (Kritis): Hook Debug BFB_DEBUG — Bot Sempurna yang Trivial

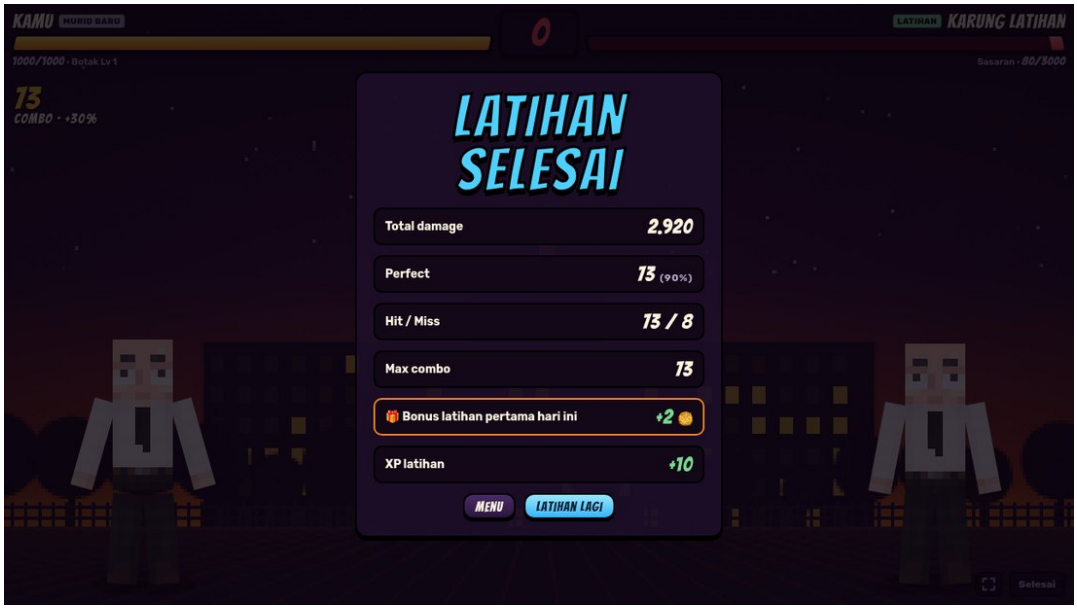
Kode klien build baru (dan build lama) mendefinisikan objek debug global **window.BFB_DEBUG** tanpa syarat apa pun, yang memaparkan: **B** (seluruh state papan, termasuk **sched** — jadwal lengkap setiap objek berisi jenis lingkaran/bom/skill, waktu muncul *a*, **waktu hit sempurna *h***, posisi *x/y*), **L()** (geometri area main), **serverNow()**, dan yang terpenting **tap(x, y)** — fungsi injeksi ketukan yang langsung masuk ke alur penilaian resmi game (judge → applyActions → antrian aksi → sendHits). Dengan dua informasi ini, sebuah bot ≈ 40 baris JavaScript cukup untuk men-tap **setiap lingkaran tepat di momen perfect-nya (±70 ms)** dan menghindari seluruh bom. Hasil PoC pada akun resmi:

80/80	10W/8L	165	5
Perfect di latihan (3594 dmg)	Rekor ranked total R3	Elo puncak (dari 39)	Kemenangan beruntun

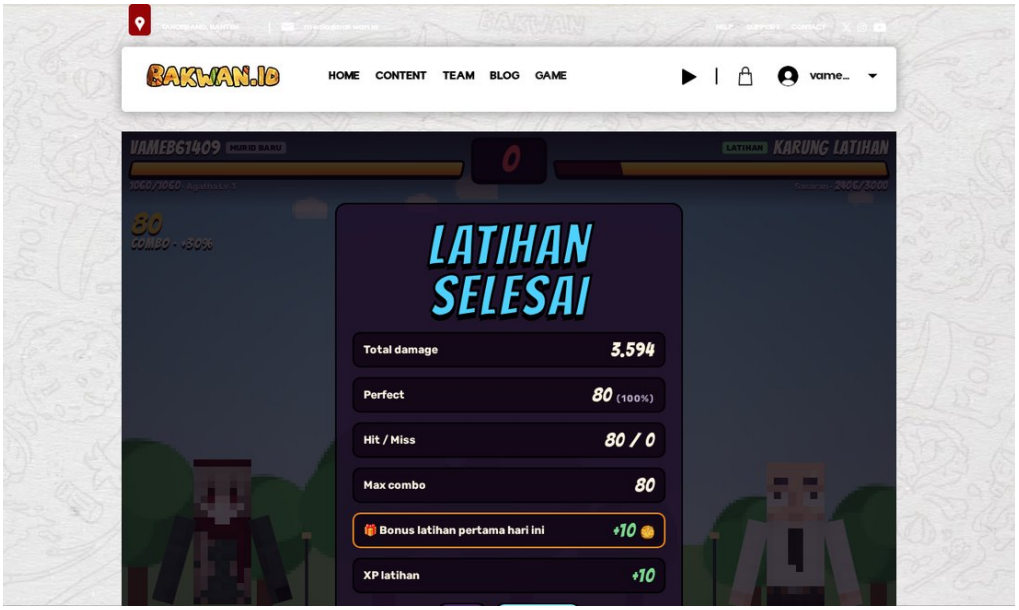
Bot dijalankan di build demo (validasi: 73/73 perfect) lalu di produksi: satu sesi latihan tercatat **80 perfect dari 80 tembakan, damage 3.594** (Gambar 64), dan enam belas match ranked melawan pemain/bot nyata menghasilkan 10 kemenangan dengan 24–32 perfect per match — termasuk lima kemenangan beruntun yang mengangkat Elo dari titik terendah 39 ke **165** (Gambar 65). Seluruh aksi bot mengalir lewat jalur aksi resmi yang sama dengan manusia, sehingga dari sudut pandang server **bot ini tak dapat dibedakan dari pemain sangat terampil**. Rekomendasi: hapus/pagari hook debug pada build produksi (mis. hanya aktif saat flag build khusus), dan pertimbangkan heuristik sisi server (distribusi offset timing, rasio perfect/jam, pola reaksi) untuk deteksi bot.



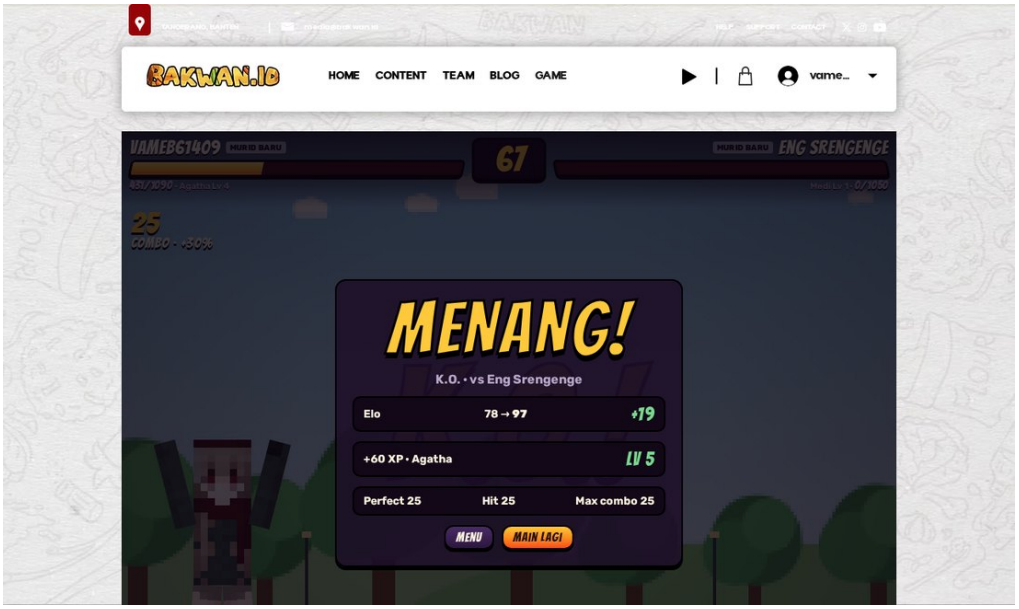
Gambar 62: Mekanik build baru: lingkaran bernomor + bom (hitam, rim merah, "!") yang wajib dihindari.



Gambar 63: PoC bot pada demo: 73 perfect dari 73, combo 73, damage 2.920.



Gambar 64: PoC bot pada produksi: 80/80 perfect, damage 3.594, daily latihan +10 bakwan.



Gambar 65: PoC ranked produksi: MENANG K.O., Elo 72→92 (+20), Perfect 24, tanpa reward bakwan.

15.4 Model Anti-Cheat sendHits: Deterministik-Replay yang Benar (dengan Catatan)

Bedah protokol pertarungan menunjukkan desain anti-cheat yang sehat secara prinsip: klien **tidak mengirim angka damage**, melainkan daftar **aksi** (id objek, kualitas, waktu) yang kemudian **disimulasikan ulang oleh server** terhadap seed match yang sama (applyActions dengan seed m.seed), lengkap dengan pencegahan inflasi (maksimum 40 aksi per panggilan sendHits, jendela waktu t ∈ [-500 ms, durasi+4 s], validasi keanggotaan match, dan penentuan koAt untuk kasus double-KO). Konsekuensinya, memalsukan angka damage atau membunuh lawan seketika **tidak mungkin** melalui jalur API. Kelemahannya tetap di sisi input: kualitas dan waktu aksi adalah **klaim klien** — server tidak dapat memverifikasi bahwa aksi tersebut benar-benar berasal dari interaksi manusia, sehingga bot sempurna pada 15.3 lolos sepenuhnya. Kombinasi "BFB_DEBUG terbuka + aksi dipercaya" berarti ladders ranked dapat dipenuhi bot tanpa jejak — berisiko

pada integritas peringkat dan nilai jual karakter gacha.

15.5 Pengerasan Server Terbukti: 37 Panggilan Probe API Ditolak Bersih

Sesuai misi “menguji logika gacha”, dilakukan 37 panggilan probe API dalam 9 kelompok uji, langsung ke server baru melalui sesi WebSocket resmi akun uji (tanpa tools eksternal, tanpa beban ke server, dan tanpa memengaruhi pemain lain). Hasilnya konsisten dan menggembirakan:

Probe	Payload	Ekspektasi celah	Hasil server
gacha(1/10/0/-1/"10"/10000)	Saldo 30 bakwan	Tarikan gratis / harga nol	NOT_ENOUGH_BAKWAN (semua)
buyItem('nope',1)	Item tidak ada	Error generik/bocor	NO_ITEM
buyItem('xpS', 0/-3/0.5)	Qty nol/negatif/pecahan	Saldo bertambah (qty negatif)	Ditolak (tidak ada transaksi)
useItem('xpS',...,-5/-99)	Qty negatif saat stok 0	Duplikasi item	Ditolak
trainDone(fake hits:50)	Ringkasan latihan palsu	XP/misi tanpa main	tooFew — server menghitung hit sendiri
selectChar(legendaries)	Karakter tidak dimiliki	Pakai Karis gratis	NOT_OWNED
demoPay(invoiceId)	Kredit invoice tanpa bayar	+100 bakwan gratis	NO_FN — rute dihapus dari server
creditPurchase(extId)	Kredit langsung	+saldo	Tidak dapat dijangkau (ctx wajib)
adminOverview/adminAnnounce/... (6 fn)	Tanpa hak admin	ACL bocor	NOT_ADMIN (semua)

Tabel 4: Hasil probe manipulasi API server play.bakwan.id — seluruhnya ditolak.

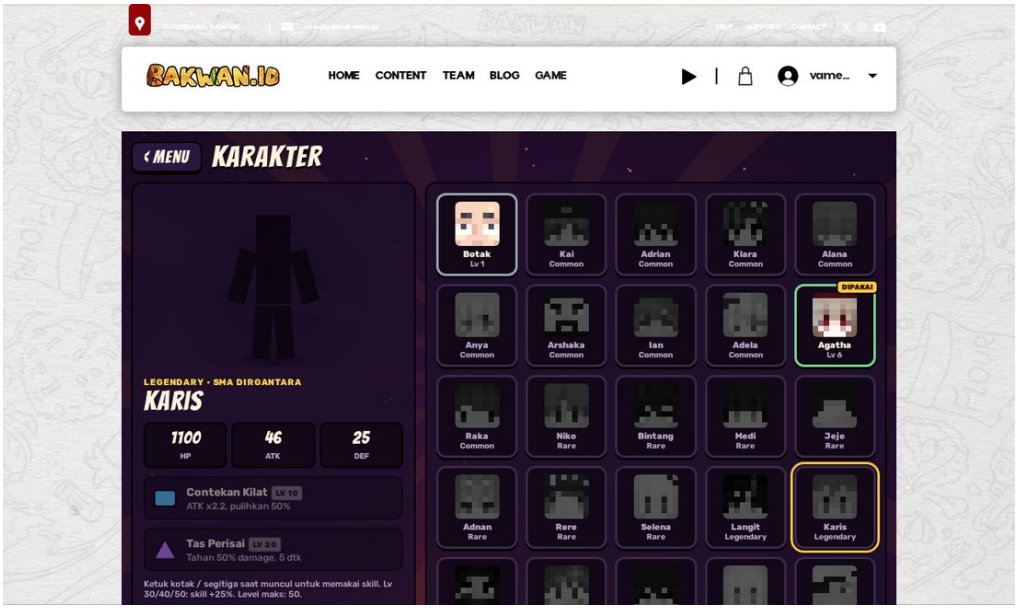
Dua temuan menarik dari proses ini: pertama, kirim argumen dalam format keliru (string bukan array) menyebabkan server mendekonstruksi argumen per karakter — responsnya tetap aman (NOT_OWNED/NO_ITEM, tanpa crash, tanpa efek data), namun sebaiknya validasi tipe argumen diperketat agar menolak permintaan malform seketika. Kedua, **tidak ada satu pun celah ekonomi yang bisa dieksploitasi**: dengan saldo 30 bakwan, tidak ada jalur menuju tarikan gacha pertama (100 bakwan) selain bermain harian atau top-up — bukti bahwa pelajaran dari BUG-05 (demo pay) dan BUG-10 (checkout) telah ditindaklanjuti serius oleh pengembang.

15.6 Analisis Ekonomi Gacha: Karis Secara Realistis Tidak Terjangkau

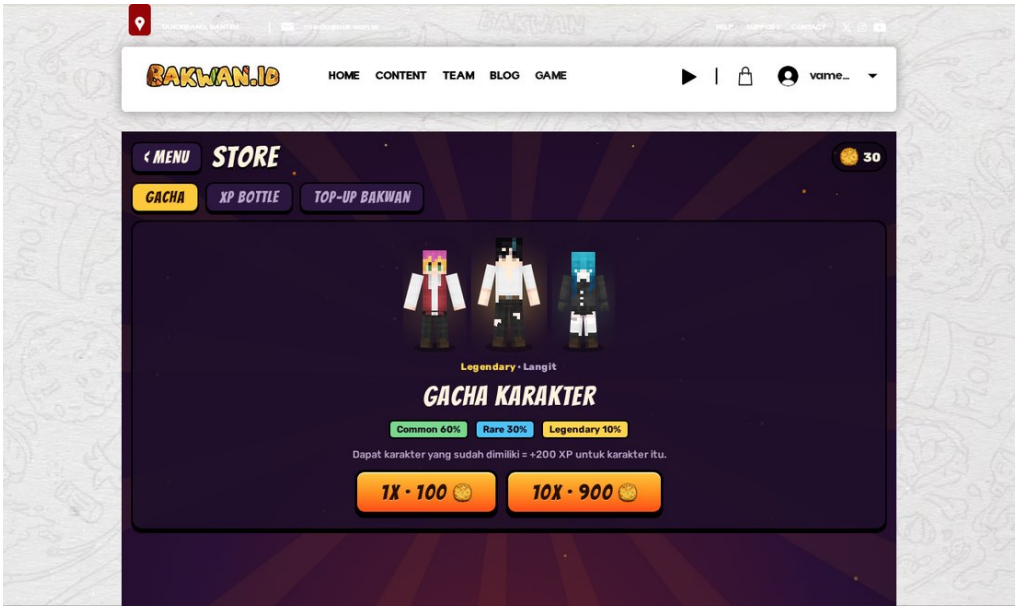
Misi memperoleh Karis diuji sejauh yang memungkinkan tanpa pengeluaran uang riil. Konfigurasi resmi build 20261025-130337 (diekstrak dari respons bootstrap akun sendiri) menetapkan: harga gacha **100 bakwan (1x) / 900 (10x)**; peluang **Common 60% / Rare 30% / Legendary 10%**; katalog **25 karakter = 10 common + 7 rare + 7 legendary**; duplikat memberi +200 XP; dan **tidak ada sistem pity** (jaminan legendary pada N tarikan) dalam konfigurasi maupun kode. Karena legendary dipilih seragam dari 7

kandidat, peluang Karis per tarikan = 10% × 1/7 ≈ **1,43%**; ekspektasi tarikan hingga Karis keluar ≈ **70 tarikan ≈ 6.300–7.000 bakwan** (63–70 paket 10x), setara **≈ Rp 283.000–350.000** pada harga diskon (Rp 50.000 per 1.200 bakwan).

Sisi pendapatan gameplay justru sangat kecil: **kemenangan ranked tidak membayar bakwan sama sekali** — diverifikasi langsung pada 10 kemenangan produksi (saldo tetap 30 sebelum/sesudah modal “MENANG!” hanya menampilkan Elo dan XP; Tabel kronologi). Satu-satunya pendapatan legal adalah hadiah harian: login +5, ranked pertama +15, latihan pertama +10 = **maksimum 30 bakwan/hari**. Dengan demikian ekspektasi Karis lewat gameplay murni adalah **≈ 233 hari** pengumpulan penuh — sedangkan melalui top-up ≈ 6 paket “Segerobak” (Rp 300.000) ditambah sisa saldo. Rekomendasi produk: tambahkan **pity counter** (mis. legendary terjamin setiap 30–50 tarikan), banner legendary terfokus, reward bakwan kecil per kemenangan ranked (mis. +2–5), atau paket langsung beli karakter — agar misi “dapatkan Karis dengan bermain” secara matematis mungkin dicapai oleh pemain aktif.



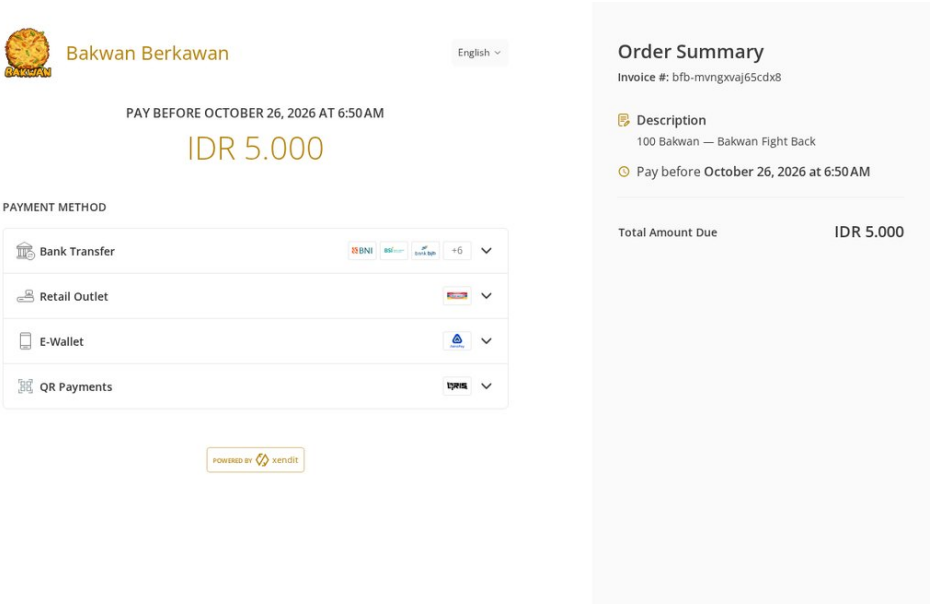
Gambar 66: Halaman karakter Karis (Legendary, HP 1100/ATK 46/DEF 25) — target misi gacha.



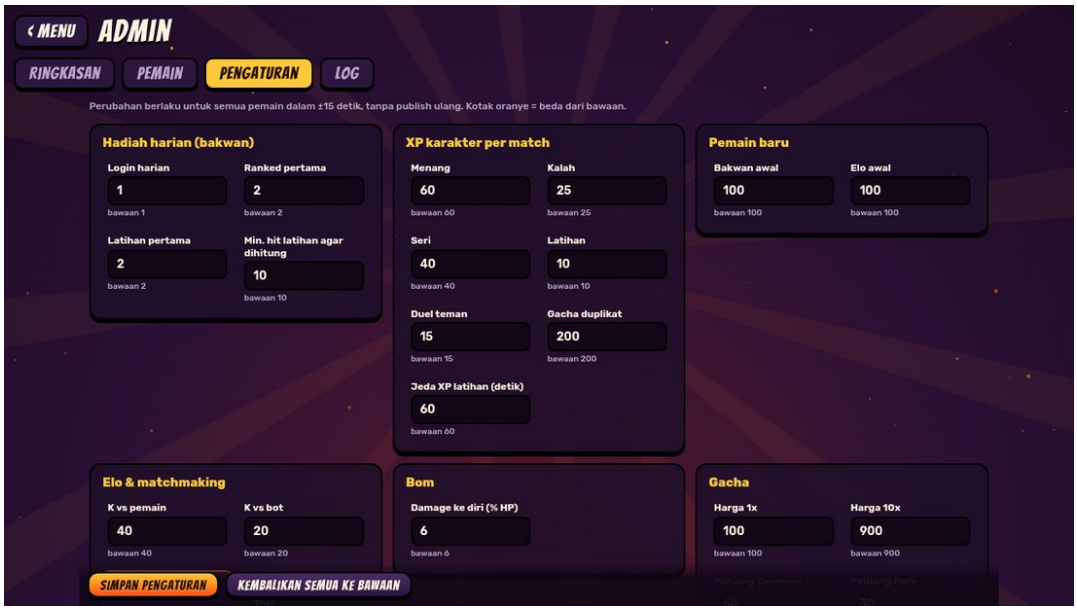
Gambar 67: Saldo 30 bakwan vs harga 100 (1x) / 900 (10x): tarikan pertama tidak terjangkau hari itu.

15.7 Status Ulang Temuan Ronde 2 pada Build Baru

BUG-10 — PERBAIKAN (diverifikasi): alur top-up Rp 5.000 kini membuat invoice Xendit mulus tanpa layar “Sorry, this wasn't supposed to happen”. Invoice uji **bfb-mvngxvaj65cdx8** terbit dengan batas bayar 24 jam, metode pembayaran lengkap (Bank Transfer, Retail Outlet, E-Wallet, QRIS) — dan **sengaja tidak dibayar** karena pengujian tidak meliputi transaksi uang riil (Gambar 68). **BUG-09 — sesuai desain (dikonfirmasi)**: server menghitung hit secara independen dari tampilan klien (uji ringkasan palsu hits:50 ditolak “tooFew”); sesi bot asli dengan 80 hit terserver langsung menggrant XP +10 dan misi harian +10 bakwan. Syarat pun dinaikkan menjadi 20 hit. **BUG-08**: menu terkait tidak lagi tampil pada UI game baru; halaman anggota Wix berada di luar iframe game dan tidak diverifikasi ulang pada ronde ini. **BUG-02/03/04**: masih hidup pada mode demo build baru (panel admin lengkap dengan kontrol ekonomi terbuka tanpa auth — Gambar 69), namun tetap terkurung di localStorage demo.



Gambar 68: BUG-10 pulih: invoice Xendit bfb-mvngxvaj65cdx8 terbit mulus (tidak dibayar — bukti perbaikan saja).



Gambar 69: BUG-03/04 masih hidup di demo build baru: kontrol server (gacha, bom, Elo) terbuka.

15.8 Log Perubahan Akun Uji pada Ronde 3

Transparansi penuh atas dampak pengujian pada akun vameb61409 (milik penyelenggara): 16 match ranked (rekor menjadi 10W/8L/0D, Elo 100 → 39 → **165**, puncak baru), 1 sesi latihan (80 perfect, Agatha +10 XP), saldo bakwan 20 → **30** (hanya dari hadiah harian latihan; tidak ada top-up terbayar, tidak ada gacha dilakukan karena saldo tidak cukup), karakter Agatha naik Lv 2 → **6** dari XP kemenangan, 1 invoice Xendit Rp 5.000 dibuat dan **tidak dibayar** (akan kedaluwarsa otomatis), nickname tidak diubah, tidak ada teman ditambahkan, tidak ada tantangan dikirim ke pemain lain, dan tidak ada data pemain lain yang disentuh. Seluruh perubahan bersumber dari gameplay normal melalui klien resmi (dengan otomasi ketukan via hook debug publik milik game sendiri) dan dapat diverifikasi pada riwayat match.